OPENBOT / ENGINEERING BASELINE

OpenBot 工程架构与项目设计

从原有研究方案到可实现的模块合同与项目计划

版本 1.2 2026 年 11 月 4 日

本轮依据27页开源组件复用评估修订：保留权威控制面，明确52个组件或组件组的采用层级、适配边界与资格验证。保留23表、14个API和授权恢复协议，形成可交给Codex或Claude Code实施的96项任务。

24 项本轮复用修订	22 项架构决策	7 张架构图
保留原32项遗漏，新增组件纠偏	控制面边界、组件准入与维护	增加自研控制面与复用边界

阅读顺序

- 先读第15章v1.2修订记录，再确认产品范围与原有遗漏审查。
- 重点阅读组件复用与资格验证，再按运行时和工具合同组织实现。
- 最后对照独立任务手册和开发交接包，逐任务交付验证证据。

使用边界

这是建议实施基线。未提供应用源码仓库，真实飞书租户、模型与三平台安装尚未验证。SQL、接口、任务与图示的离线检查结果随交接包提供。

目录

01 OpenBot 产品范围与工程基线 3

02 遗漏项与原方案修订 5

03 系统架构与模块边界 8

04 任务状态机与崩溃恢复 10

05 权限模型与审批协议 13

06 数据模型与接口合同 16

07 执行器与模型接入设计 21

08 飞书入口与远程交互 24

09 桌面产品与跨平台交付 26

10 验证体系与运行维护 28

11 项目计划与AI编码交接 30

12 架构决策与证据索引 33

13 开源复用策略与组件准入 38

14 组件验证与接入门禁 43

15 v1.2修订记录与实施顺序 46

16 架构图册 49

01 OpenBot 产品范围与工程基线

版本 1.2 · 2026 年 11 月 4 日 · 状态为建议实施基线

本次结论

保留前两份材料已经形成的方向：Python 薄内核、自有任务与策略模型、飞书优先、SQLite 本地持久化、Tauri 作为桌面入口、执行器和模型可替换。v1.2根据新增的27页组件复用评估，明确默认组件、条件候选、源码参考与暂缓项，增加组件准入、离线资产、SDK副作用和平台资格验证。工程设计包不是已经实现的 OpenBot 应用；其中 SQL、JSON Schema、接口定义和任务依赖经过静态或离线验证，真实飞书、真实模型和三平台安装仍须由后续任务验证。

设计版本1.2不等于所有通信协议都升级为1.2。本轮保留23张数据库表、14个本地API操作和原有授权/恢复协议；组件清单、验证模板及任务计划独立版本化。实际接口变化仍须独立合同迁移，不能全仓替换版本号。

最先开发的产品是一个由用户控制的本地常驻助手：在指定工作区检索资料、解释代码、生成补丁、经授权执行隔离测试，并通过飞书或本地 CLI 查看进度、确认动作、取消和恢复任务。明确区分三个交付层级：本地闭环原型、符合原研究稿能力范围的 MVP、具备桌面安装与诊断体验的 Beta。

输入与证据边界

输入 U1 是《OpenBot 开源桌面智能体深度研究报告》，共 20 页；U2 是《OpenBot 架构设计与任务规划》，共 36 页。页码使用 PDF 物理页码。U1 第 14 页列出单用户 daemon、至少两个 Provider、文件 Shell Browser MCP、飞书与三平台 CLI 等 MVP 能力；本方案通过分阶段门禁保留这些目标，不把桌面 Computer Use 提前为 MVP 必选项。

未提供源码仓库、已完成清单、锁定依赖、目标飞书租户或性能实测。因此所有任务初始状态为 TODO；原材料中的工期、Stars、精确冷启动耗时、成功率和竞争产品结论不作为实现验收依据。标为“建议”“目标”“默认”的值都是本次设计决定，不能对外当作已经测得的产品能力。

默认假设

编号	本方案采用的默认值	对实现的影响
A01	一个 OS 用户、一个 OpenBot profile、一个 owner、一台执行设备	本地配置与身份隔离；不做企业多租户
A02	一个自建飞书应用只连接一个活动 gateway	消除竞争消费导致的设备路由丢失
A03	先交付 CLI 和飞书；Tauri 在内核门禁通过后接入	UI 不成为运行时的依赖
A04	三平台核心协议从第一天 CI；真实打包按平台分别验收	不用 WSL 代替 Windows 原生测试
A05	试点打包优先 macOS ARM64，Windows x64 与 Linux x64 随后；实际主机不匹配时通过 ADR 调整	这是默认排程，不是已经确认的用户环境要求
A06	用户自备模型凭据与飞书自建应用；模型费用直接归用户账户	无中央收费与模型代理服务

编号	本方案采用的默认值	对实现的影响
A07	远程执行代码需要可用的隔离后端；没有后端则拒绝该能力	不静默降级为宿主机任意命令
A08	初期不承诺唤醒休眠或关机电脑	网络重连恢复与远程硬件唤醒是不同能力
A09	生成补丁默认放在独立工作树或暂存区；应用到用户原目录需要明确动作	不覆盖既有未提交修改
A10	所有架构建议均可由 ADR 修改，但变更必须同步合同、任务和验收	避免两个编码助手形成相互矛盾的实现

目标用户与关键场景

S01 代码诊断：用户在飞书指定工作区和问题，助手读取允许范围内的文件，生成带来源路径的诊断及补丁草稿，不自动提交或推送 Git。

S02 隔离验证：用户审阅将运行的 argv、代码快照和网络权限，批准后在隔离环境运行测试；输出保存为有体积上限的 artifact，卡片展示摘要。

S03 长任务恢复：用户隔数小时审批，期间 daemon 重启。系统恢复已经持久化的任务；对结果不明的外部动作进入核对流程，而不是自动重发。

S04 取消与接管：用户从任一已授权入口取消任务，阻止后续动作；对于已经发生的修改或消息发送明确展示实际结果，不显示虚假的“已撤销”。

S05 浏览器查阅：使用 OpenBot 专用浏览器配置读取获准域名；浏览器页面内容视为外部输入。网页提交、文件上传、购买或向第三方发消息必须绑定具体动作审批。

S06 离线工作：OFFLINE 模式仅允许本地模型、工作区和本地工具；飞书和网络浏览器处于禁用状态。LOCAL_MODEL 模式仅限制模型出口，仍可按单独授权连接飞书。

交付范围

层级	包含	完成标志
M0 设计与风险验证	仓库骨架、合同、威胁模型、飞书 SDK 与进程监督 spike	无未解决的 P0 架构问题
M1 本地闭环原型	CLI、持久化、一个 Provider、文件 ACI、审批与恢复、隔离进程	断网可用 mock 演示；安全边界测试通过
M2 远程闭环	飞书配对、消息去重、审批、Outbox、断连恢复	测试租户完成真实端到端任务
M3 产品 MVP	至少两个 Provider、受控 Browser/MCP、三平台 CLI、评测与备份	原 U1 MVP 范围有明确能力报告
M4 桌面 Beta	Tauri、签名安装、升级回滚、诊断与操作面板	干净机器安装和升级恢复通过
后续	GUI 控制、定时任务、更多渠道、多设备、企业策略	独立 ADR 与任务，不阻塞前述交付

三平台一致指合同、行为和错误码一致，不代表所有 OS 原生能力相同。macOS/Windows 的隔离代码执行可以依赖 Linux 容器后端，但这不等于支持原生 PowerShell、Win32 或 macOS 自动化。能力探测必须把这种差异显示给用户。

非功能目标

领域	初始目标	测量条件或边界
飞书回调	协议要求 3 秒内响应；内部处理目标 p99 小于 1 秒	测试租户、稳定网络、1000 次回调；不得把目标写成官方保证 [S01]
持久化	收到成功提交确认的任务可在进程崩溃后查询	WAL 加 FULL；断电还受 OS 与存储实际持久化能力影响 [S03]
动作安全	未授权动作执行数为零	指指定测试集及路径，不宣称“绝对安全”
恢复	进入确定状态或待核对状态；不重复执行非幂等动作	在所有规定崩溃点注入故障
预算	每个任务具备步骤、调用、时间与费用上限	费用按 provider 返回使用量或估算标记记录
资源	单 profile 默认一个活动任务、一个浏览器动作、一个写工作区任务	先串行，后续再扩展锁调度
可用性	daemon、gateway、executor 的健康分别可见	UI 已连接不等于远端与执行器健康
隐私	凭据不进入模型上下文、普通日志与默认诊断包	以合成 canary secrets 验证，而非只依赖正则替换

代码量只用来观察复杂度，不设置 5000 到 15000 行的硬交付门槛。把安全、恢复和合同测试挤出所谓薄内核，会让代码看起来短而让行为不可控。

02 遗漏项与原方案修订

审阅方法

以下区分“原文缺失”“提到但未闭环”和“建议修正”。保留原方案已经有效的部分，重点补全执行、持久化、身份、平台和交付的边界。U2 已覆盖审批、WAL、进程清理、MCP pinning 等概念；不能把这些重复列成全新发现。

必须在编码前修正的事项

ID	类型与原文位置	问题及后果	本次决定与验收
G01	原文缺失；U2 第 9 至 11 页	3.1 后直接接审批 SQL 和 3.4，3.2/3.3 未形成完整正文；第 10 页混入导出残留	以本包状态机、合同与 DDL 为完整基线；扫描断链、占位、编号和代码可解析性
G02	建议修正；U1 第 6/14 页，U2 第 22 至 24 页	常驻 daemon 与 UI 退出即杀内核的生命周期矛盾	daemon 由用户级 supervisor 管理；关闭 UI 不停任务；停止服务才关闭 workers

ID	类型与原文位置	问题及后果	本次决定与验收
G03	提到但未闭环；U2 第 17 至 20/30 页	checkpoint 与事件不能证明外部动作是否已经完成	分开 Task 与 Operation；增加 UNKNOWN 和 RECONCILING；发送成功但未落盘时不得盲重试
G04	提到但未闭环；U2 第 10/19 页	CAS 只解决一次批准；没有批准后执行 claim 和完整身份授权	绑定 actor/profile/channel/workspace/tool/content/policy，执行前重新校验与原子 claim
G05	提到但未闭环；U1 第 7 页，U2 第 17 页	lease 没有 fencing，旧 worker 恢复后仍可能执行	OS 单实例锁、单 broker、epoch、资源锁；不能停止旧动作时不接管执行
G06	建议修正；U2 第 7/16 页	NORMAL 配置与“断电后 100% 恢复”冲突	控制库 WAL 加 FULL，区分进程崩溃与系统断电，备份恢复另行验证 [S03]
G07	提到但未闭环；U2 第 11/16 页	5000ms busy_timeout 或长 writer 队列可能超过 3 秒回调期限	回调事务设总 deadline 与可取消队列，临近期限尚未开始则失败关闭
G08	建议修正；U2 第 29 至 30 页	“发卡后等待45分钟”不能测试交互 token 过期	token 由回调携带；应先点击再推进 token 时钟；批准有效期独立于卡片 token [S02]
G09	原文缺失；U1 第 7/13 页	同一飞书 app 多电脑竞争消费，收到消息的电脑未必拥有目标任务	MVP 单 app 单活动 gateway；多设备采用中心路由方案另立阶段 [S01]
G10	建议修正；U2 第 1/7 页	出站 WebSocket 不会自动唤醒休眠或关机电脑	承诺在线远程控制和唤醒后重连；Wake-on-LAN 或 relay 另做能力
G11	提到但未闭环；U2 第 4/20 页	schema hash 只验证描述稳定，不能约束 MCP 实际行为	执行隔离、出口控制、完整定义摘要、包 digest、变更隔离和凭据最小化
G12	提到但未闭环；U2 第 12 至 15 页	Browser Use/UFO 自己运行循环时可能绕过中央审批	只接原语或受控 hook；无法逐动作截获则插件不得获得写/外发能力
G13	建议修正；U2 第 13/15 页	argv 与路径字符串校验不等于沙箱；Python、测试脚本、Git hooks 都能执行代码	所有不可信代码均走隔离执行器；禁止用“pytest是白名单”证明安全
G14	提到但未闭环；U2 第 15 页	realpath 后再打开仍有 TOCTOU；Windows ADS、junction、UNC、硬链接未完整覆盖	安全目录句柄与执行时复验；默认拒绝特殊路径；用原生平台攻击样本验收
G15	建议修正；U2 第 5/6 页	LOCAL_ONLY 混合了模型隐私、远程入口与所有网络出口	配置拆为模型出口和网络模式；OFFLINE 与飞书互斥
G16	原文缺失；U2 第 15/20 页	原始 stdout、截图、artifact 本身可能带凭据；仅日志脱敏不足	内容分级、默认不远发、密钥托管、大小与保留期限、诊断导出预览
G17	提到但未闭环；U2 第 23 页	spawn 后加入 Job 有窗口；启用 BREAKAWAY_OK 破坏默认整树归属	原生监督按挂起创建再入 Job 后恢复；检查所有返回值；正常任务禁止 breakaway [S08]
G18	建议修正；U2 第 24/31 页	Python 已被 SIGKILL 后无法执行 EOF 清理；macOS 进程组不是恶意逃逸隔离	清理由独立 supervisor 承担；区分正常进程回收与恶意进程约束

ID	类型与原文位置	问题及后果	本次决定与验收
G19	原文缺失；U2 第 18/20 页	审计“只追加”与任意级联删除矛盾；记忆跨项目权限不清楚	状态与审计分别保留；默认不级联抹去审计；记忆须有 scope、出处和失效规则
G20	原文缺失；U2 第 17/21 页	外发 outbox 没有收件人/消息 revision/结果不明/重启恢复语义	outbound 操作有固定收件目标、序号、去重能力、UNKNOWN 与死信重放规则

项目与产品层面仍需补全的事项

ID	原始不足	设计补充
G21	18 个工作包跨度较大，难让代码代理单次完成	拆成带依赖、改动边界、证据和验收的任务卡；一次只做一个可审查增量
G22	模型适配只有名称，无能力差异约定	统一文本/工具/使用量事件；Provider capability negotiation、严格参数解析与中断处理
G23	外部数据进入模型即外发，却仅给 message.send 审批	ModelGateway 同样通过数据分类和出口策略；敏感目录不能自动进入云模型
G24	无 UI 交互约束	入门、任务时间线、审批详情、待核对结果、能力缺失、诊断与升级七条核心流程
G25	无数据库迁移与跨版本升级策略	migration checksum、schema版本检查、备份、只读维护模式与数据回滚边界
G26	无 artifact 生命周期	不可变对象、sha256、owner/scope、大小、TTL、引用计数、清理与备份清单
G27	无预算分配及重复循环识别	在调用前 reserve，完成后 settle；重复动作上限；取消和超时传播
G28	无完成判定，容易把模型“完成了”当事实	outcome verifier 核对产物和断言，区分 SUCCEEDED、PARTIAL、FAILED
G29	无费用与评测基准	固定任务集、环境快照、模型配置和成本报表；mock 只验证控制逻辑
G30	无运行维护与支持流程	doctor、自检、脱敏诊断包、备份恢复演练、凭据吊销、熔断和事故处理
G31	定时任务提到 Cron，但时区/漏跑/重复未定义	后续明确 timezone、DST、misfire、并发和每次执行的授权，不把历史批准永久复用
G32	无依赖、许可证和发布供应链基线	锁定依赖与工具包、SBOM、许可证清单、签名密钥分离、构建来源与更新验证

避免把证据写成保证

U2 中“24.27 秒冷启动”“首次连接 100% 失败”“重连必定 30 秒内”“一秒内所有子孙进程消失”“稳定性百分比”等描述，缺少在目标版本、机器和负载上的复现实验，不能进入本项目的能力承诺。将它们替换为版本化测试场景和可测

量的目标。

macOS TCC 提示周期、SDK 内部方法名和第三方权限插件支持范围都是随版本变化的细节。开发时通过 capability probe 与真实机器测试确认；不要把“某个系统版本必定每30天提示”写死为核心逻辑。

“模型输出带污点”是来源追踪，不是注入已经被清除的证明；“用户点击批准”是对特定动作授权，不是对整个会话全部后续行为的授权；“日志可回放”是观察历史，不是再次执行外部副作用。

03 系统架构与模块边界

总体设计

采用单机模块化架构。控制平面是一个 Python daemon，统一持有任务、审批、调度与 SQLite 写连接。飞书 gateway 为隔离故障的独立进程；工具 worker 按执行域隔离。原生 supervisor 负责进程监督；Tauri UI、CLI 和飞书都是客户端，不持有任务权威状态。

图 1 系统与信任边界。完整图见文末架构图册；可编辑源文件随开发交接包提供。

组件	负责	不负责	持有的数据
User Supervisor	启停、单实例、退出清理、日志通道、升级切换	模型决策与业务审批	profile锁、子进程归属、启动epoch
OpenBot Daemon	身份、任务、策略、审批、调度、状态提交	浏览器页面直接渲染或运行任意插件代码	唯一 SQLite writer、操作状态
Feishu Gateway	SDK连接、回调转换、消息卡片、重连	判断owner权限、直接执行工具	仅飞书凭据、短期连接状态
CLI / Tauri	展示、输入、确认、诊断入口	数据库直连、绕过策略、发任意shell	范围受限的本地会话
Tool Broker	preflight、claim、资源锁、worker分派、结果归档	用模型文字推断权限	operation与dispatch关联
Isolated Worker	执行已绑定的一个能力或受限批次	自发调工具、读取核心库与所有密钥	最小输入、专用暂存目录
Model Gateway	模型协议、能力、出口策略、用量	决定工具是否允许	选定上下文与对应provider密钥
Artifact Store	不可变产物、内容哈希、引用与保留	作为任意本地路径文件服务器	受控对象及metadata

M1的policy、scheduler、storage、context和broker可以是同一daemon内的清晰模块；只把不可信代码、易阻塞SDK、native parser与浏览器等放到需要的进程边界。v1.2将第三方能力落实为类型化port/adapter，详见12_component_reuse；任何SDK或框架不能接管权威状态、审批和UNKNOWN恢复。

物理进程与生命周期

图 2 进程生命周期。完整图见文末架构图册；可编辑源文件随开发交接包提供。

常驻模式是产品默认：用户级 supervisor 启动 daemon，daemon 启动 gateway 和受控 workers。Tauri 启动时连接已有 daemon；关闭窗口仅关闭显示层。托盘“停止 OpenBot 服务”才执行 drain、停止新任务、撤销未开始 dispatch、回收 workers、提交最终状态、关闭数据库。

开发用 ephemeral 模式可让 CLI 启动一次临时 daemon，并在命令结束时关闭；模式必须显式标识，不能与常驻安装混用。服务自动重启后生成新的 runtime_epoch，旧连接与执行许可失效。休眠、用户注销、OS重启分别是不同事件；自动启动不能被解释为后台登录态永远存在。

父进程清理的归属是 supervisor，而不是某个 UI 窗口。macOS 管道 EOF 可以用于正常或崩溃通知，但不能把仅依赖 Python 自救当作强制杀死后的清理保证。Windows 进程用 Job Object；Linux 优先用户级 cgroup，条件不足时进程组只提供协作式回收。所有能力以 doctor 实测结果为准。

信任与数据流

信任层级分为用户授权、系统策略、模型建议、外部数据四类。每个身份由接入边界经过校验后产生；模型、卡片 action value、文档内容均不能写入 is_owner 或 permissions。外部数据的摘要、记忆和模型再转述仍保留来源范围，不因“内部模型生成”而升级为授权。

入口数据流为：接入验证、归一化、去重、事务落盘、调度任务。工具数据流为：模型提案、工具合同校验、确定性策略、必要审批、执行前复验、原子 claim、worker、结果提交。任何插件内嵌循环都必须服从同一流程。

通信使用本地 HTTP 加 SSE 作为第一版 transport。只绑定 loopback，校验 Host 和 Origin，不允许任意 CORS；UI WebView 不直接获得广域管理员 token，优先经 Rust command 代理。token 不进入 URL、日志或前端静态资源。启动使用 OS保护的描述文件或继承句柄协商，不采用先找空闲端口再关闭再监听的竞态方式。

在本地同一用户已经被恶意程序完全控制的威胁模型下，普通用户态 token 和 SQLite 文件权限不能提供强安全边界。本项目主要防御模型误操作、恶意输入、第三方工具越权、网络未授权访问与运行故障；更强本机对抗需要独立用户、OS sandbox 或 VM。

模块目录

```
openbot/
 apps/cli/
 apps/desktop/            # Tauri 后置接入
 services/core/src/openbot/
  domain/               # 状态、事件、值对象
  application/          # 用例、调度与恢复
  policy/               # 身份、能力、审批、出口
  storage/              # repositories、事务、迁移
  providers/            # 统一模型网关
  tools/                # broker、manifest、原语
  artifacts/
  observability/
 services/feishu_gateway/
 native/supervisor/
 contracts/              # JSON Schema 与 OpenAPI
 db/migrations/
 tests/unit/
 tests/contracts/
 tests/integration/
 tests/security/
 tests/chaos/
```

```
evals/
docs/adr/
```

推荐Python 3.12作为初始验证基线，uv管理分阶段依赖组与锁；Pydantic用于DTO，完整jsonschema验证用于合同与不可信Schema边界，FastAPI提供本地接口；sqlite3或aiosqlite只在storage层使用。Rust与Tauri选用开发时核实过的版本。M0记录核心环境，飞书、浏览器、MCP等在对应任务锁定和资格验证，不在启动阶段一次安装全部候选库。

依赖方向是 adapter 调用 application，application 调用 domain 与 port，基础设施实现 port。domain 不依赖飞书、FastAPI、Tauri或具体模型SDK。禁止在channel回调中创建AgentLoop；禁止UI直接打开SQLite；禁止provider函数执行工具。

运行容量与并发

MVP默认每profile一个活动任务；同会话输入按序排队，用户可显式取消或补充当前任务。全局只允许一个GUI动作队列。工作区修改持有workspace写锁；浏览器profile持有独占锁；消息外发按recipient与operation串行。等审批释放计算槽位，但保留操作记录，不长期持有数据库事务或worker进程。

后续可提高只读任务并发，但必须先实现有序多资源锁。资源键至少包括 workspace、browser_profile、desktop_session、external_account。持锁不能跨人工等待；恢复时重新获取并校验资源版本。租约用于发现失联，fence用于拒绝旧写者；对无法识别fence的外部系统，不能声称仅凭租约即可防止重复副作用。

04 任务状态机与崩溃恢复

状态与权威数据

MVP采用“事务状态表加只追加审计日志”，不实施完整事件溯源。tasks、operations、approvals是当前状态的权威；events是审计与UI增量流。状态更新、对应事件与通知outbox在同一数据库事务提交。恢复扫描权威表与operation ledger；历史事件回放用于审阅，不直接再次运行工具。

一项Task表达用户目标，一项Operation表达一次具体外部或本地动作，一个Attempt表达该Operation的一次执行尝试。模型调用也要有记录与预算，但它可以在预算内重试生成；不能把“再生成一次提案”与“再执行一次已批准动作”混为一谈。

Task状态

状态	进入条件	允许的后续
QUEUED	已持久化但未获得调度槽	RUNNING、PAUSED、CANCELLED
RUNNING	正在规划、校验或执行	WAITING_APPROVAL、WAITING_INPUT、WAITING_RESOURCE、RECONCILING、PAUSED、SUCCEEDED、PARTIAL、FAILED、CANCELLED
WAITING_APPROVAL	存在明确待批准Operation	QUEUED、PAUSED、FAILED、CANCELLED
WAITING_INPUT	缺少必要参数或需用户处理登录	QUEUED、PAUSED、FAILED、CANCELLED
WAITING_RESOURCE	缺少网络、模型、沙箱、权限或资源锁	QUEUED、PAUSED、FAILED、CANCELLED

状态	进入条件	允许的后续
RECONCILING	有结果不明或需核对的动作	QUEUED、PARTIAL、FAILED、CANCELLED；有未解决UNKNOWN时不能直接标成功
PAUSED	用户暂停、预算耗尽、升级维护	QUEUED、CANCELLED；恢复前重新核对前置条件
SUCCEEDED	验证器确认目标产物与要求完成	终态；继续请求产生新Task
PARTIAL	部分产物可用，仍有明确未完成内容	终态；记录哪些动作已完成
FAILED	无法继续且有明确错误原因	终态；重试通过新Task或受控恢复命令
CANCELLED	后续执行已停止且没有未核对的外部动作	终态；不表示过去的外部效果已回滚

取消通过cancel_requested_at和cancel_revision持久化传播。任务收到取消请求后立即停止派发新动作；若存在DISPATCHING或UNKNOWN，则显示“正在停止或核对”，继续停留在RECONCILING，不能提前宣告所有效果已经取消。

Operation状态与原子边界

图 3 操作执行与恢复。完整图见文末架构图册；可编辑源文件随开发交接包提供。

PROPOSED经过schema和policy检查后进入READY、AWAITING_APPROVAL或REJECTED。审批成功仅进入READY。Broker在同一个事务里检查任务、身份、policy、grant和资源版本，消费批准，创建attempt，并把Operation改为CLAIMED。

在向执行器发送任何可能触发外部效果的指令之前，必须以第二个短事务复核取消、epoch和资源仍有效，再持久化DISPATCHING与该Attempt的固定dispatch_id。worker/broker保存dispatch接收ledger。明确结果落盘后进入SUCCEEDED或FAILED。任何“发出指令后没有获得可验证终态”的场景进入UNKNOWN，而不是根据超时推断失败。

CLAIMED但未进入DISPATCHING的操作，在确认旧runtime已被隔离且没有派发记录后可重新排队。DISPATCHING及其之后发生故障，必须按工具类别处理。拒绝、过期、撤销、取消都是终止当前Operation；重新审批或改变参数会创建新的Operation。Approval一旦CONSUMED永不退回APPROVED；同Operation的安全重试沿用既有消费关系，不二次消费，但每次仍复验原授权期限、policy、身份、取消和资源。任何条件变化都新建Operation。

工具重试分类

retry_class	例子	崩溃后的处理
SAFE_READ	读取不可变artifact，查询允许范围文件	可重试，但记录读取版本；文件已变更时更新观察
IDEMPOTENT_WRITE	按旧文件hash应用指定patch、写内容寻址对象	用前置条件、目标hash与operation_id核对，确认未完成才再执行
PROVIDER_IDEMPOTENT	外部API明确支持幂等键和有效期	使用原幂等键，在provider约定窗口内查询或重试；过窗转UNKNOWN
RECONCILE_ONLY	网页点击发送、GUI提交、不具备去重语义的消息API	查询远端结果或请求用户核对；禁止自动再次提交
NON_RETRYABLE	不支持核对的高风险不可逆动作	默认不开放；手工处理后记录结果和证据

重试策略来自本地经过审核的tool manifest，不能采信第三方MCP的readOnlyHint或idempotentHint作为授权依据。[S05]

恢复算法

1. 获取profile独占OS锁，创建runtime_epoch，验证schema与磁盘状态；无法确认唯一活动runtime时拒绝执行模式。
2. 询问supervisor，停止或隔离前一epoch仍存活的workers。无法证明旧执行器已失效的资源进入WAITING_RESOURCE。
3. 扫描非终态tasks、未终态operations、未发送outbox与未处理inbox，按事务状态恢复，不重新运行历史事件。
4. 过期待审批请求标EXPIRED；已批准但policy、workspace或identity变化则REVOKED；不能保证旧卡片一直有效。
5. CLAIMED操作满足安全条件时可回到READY；DISPATCHING操作转UNKNOWN并按retry_class核对。
6. 对明确可重试的动作创建新的attempt与新的dispatch_id，保留原operation_id与provider_idempotency_key；同一attempt的消息重传才复用dispatch_id。不可重试动作进入RECONCILING。
7. 向用户发送恢复摘要，明确已完成、待审批、结果不明和仍不可用的能力。

故障注入表

崩溃点	已落盘内容	恢复应有结果
入站事务提交前	无inbox	不ACK成功；等待平台重推或用户重试
入站提交后ACK前	inbox与task	同事件再次到达被去重；只保留一个逻辑Task
批准提交后卡片响应前	APPROVED与READY	UI可能提示超时；重复查询显示真实状态，不能重复授权
claim提交后dispatch前	CLAIMED	旧worker已隔离后可安全恢复；不消耗第二次批准
DISPATCHING提交后发包前	DISPATCHING	仍按可能已执行处理；安全优先，必要时进入UNKNOWN
外部成功后本地落盘前	DISPATCHING	远端查询或人工核对；禁止直接再发
outbox远端发送后本地标记前	IN_FLIGHT	按远端幂等能力核对；不能保证恰好一次通知
结果写入后UI更新前	SUCCEEDED与outbox	UI重新订阅事件或读取快照恢复正确显示
磁盘满或writer故障	提交失败	停止新派发；不以内存成功代替durable成功

并发与时钟

MVP单活动Task仍需要处理回调、取消、心跳与outbox并发。所有状态转换检查expected_version并递增version；每个attempt带runtime_epoch与fencing_token。Broker只接受当前epoch和未消费dispatch。外部API不支持fence时，不能仅靠数据库租约让第二个worker接管同一动作。

持久时间使用UTC毫秒；单进程超时使用单调时钟。系统时钟倒退、休眠恢复和时钟大幅跃迁触发重新检查。跨重启无法可靠证明未过期的敏感授权应失效重审。不要只比较客户端传入的时间戳。

验证目标完成

模型的final文本只能申请完成。OutcomeVerifier必须核对约定产物、必要测试结果、未解决审批、UNKNOWN动作和预算记录。诊断任务至少产出来源引用；补丁任务至少产出diff与原文件hash；测试任务至少产出命令、快照、退出码与日志摘要。只完成部分要求时为PARTIAL，并清楚告知遗漏。

全局终态与恢复守卫

所有进入CANCELLED的边都要求不存在DISPATCHING或UNKNOWN动作；仍有不确定效果则停在RECONCILING。普通resume只能恢复可恢复任务，不能跳过核对使RECONCILING直接进入运行。只有恢复器确认所有相关未知结果已按工具语义解决，才允许重新QUEUED。

UNKNOWN期间相关workspace、browser profile或external_account持有持久quarantine锁；新Task或新Operation不能借更换ID绕过它重复同类写动作。无关只读工作可继续。人工核对通过专用接口提交证据、expected_operation_version与明确结论；系统区分PROVIDER_VERIFIED和USER_ATTESTED，不能把模型输出当核对证据，也不把人工确认伪装成远端API证明。

05 权限模型与审批协议

保护目标与默认拒绝

需要保护的资产包括工作区文件、用户凭据、浏览器登录态、外部账户、审批授权、运行配置与审计记录。输入中的网页、README、Issue、邮件、MCP描述、工具输出和模型回复都不能赋予权限。策略由代码、受控配置与已认证用户的具体授权组成。

风险不能仅由“工具名属于L0还是L2”确定。一次read可能泄露秘密，一次浏览器导航可能向恶意域名携带信息，一次pytest可能执行任意仓库代码。因此Decision取决于actor、resource、action、data_class、destination、execution_backend与当前授权。

决策	适用例子	限制
ALLOW	范围内普通文件读取、只生成本地草稿、读取脱敏状态	仍记录来源、边界与预算
ASK	应用补丁、隔离代码执行、上传文件、具体外发	绑定精确操作和资源版本
DENY	未配对身份、敏感路径、禁用能力、未知工具、禁止出口	远程点击批准不能覆盖硬拒绝
REQUIRE_LOCAL	更改安全策略、增加工作区、配置凭据	需本地已认证设置流程

审批频率由用户创建的有限capability grant减少，而不是“信任整个聊天窗口”。MVP禁止TRUSTED_HOST_EXECUTION，包括审核过的第三方MCP程序。若未来增加可信宿主执行，必须独立ADR和本地启用，不作为隔离失败的兜底。MVP可以配置允许的工作区读取；对任意程序执行、第三方发送和浏览器写动作默认一次一审。后续限时、限目录、限金额或限工具的grant必须有独立数据模型。

身份与会话绑定

飞书身份键为tenant_id、app_id、external_user_id的组合；chat_id不是用户身份。channel_instance与profile绑定；callback.operator经过验证后映射principal_id。禁止从action.value读取“我是owner”、role或批准者姓名作为权威。

配对流程必须由本地登录用户发起，创建单次随机挑战，设置短TTL和尝试次数；飞书回传只能形成待确认配对。本地显示tenant、app、用户标识并确认后才成为owner。不能让远端第一个发送消息的人自动获得owner权限。二维码只是挑战的显示方式，不是身份本身。

MVP不启用群聊执行；若后续开启群聊，必须明确谁可触发任务、谁可看到结果、谁可审批以及哪些结果只私聊返回。回到原任务owner的状态通知属于已授权反馈，向第三方发送内容则是独立敏感动作。

不可变提案与审批绑定

提案包含profile_id、principal_id、session_id、task_id、operation_id、workspace_id、tool_name、tool_version、tool_manifest_digest、canonical_args、resource_snapshot、data_class、destination、policy_version、identity_epoch、expires_at和approval_nonce_hash。原nonce仅保存在受保护challenge store，不作为完整内部提案的普通可导出字段。

使用约定的规范化JSON方案构造binding，计算SHA-256。JSON字段排序、浮点数、Unicode和无效值必须明确约束；采用RFC8785实现与golden vectors，不能把不同语言的默认JSON序列化当作跨语言规范。[S06] 本地Python为hash的唯一权威，UI只展示server提供的digest。浮点高风险参数优先使用整数最小单位或十进制字符串。

v1.2选择经测试的rfc8785库；JCS键按UTF-16 code units排序，而不是Python默认Unicode码位序。输入先拒绝重复键、非法Unicode、NaN/Infinity和不支持的数值域；不把任意大整数强行转float。Pydantic的frozen是浅层保护，嵌套dict仍可能变化，因此服务端必须生成并保存权威canonical bytes/摘要，执行前从权威记录复核，不依赖可变DTO引用。[R01][R02]

审批卡片只携带不透明approval_id、nonce与显示用短hash；完整提案保存在本地。对外GET审批返回独立ApprovalPreview DTO而不是ToolProposal原件；预览被过滤不改变原binding_hash。本地预览同样不得展示SECRET值，只展示secret handle和用途。敏感命令和diff在飞书显示经过数据策略过滤的足够预览；如果不能安全展示完整影响范围，要求本地审批，不能让用户盲批截断内容。

两阶段检查与执行claim

图 4 批准与派发时序。完整图见文末架构图册；可编辑源文件随开发交接包提供。

第一次检查发生在用户点击时：验证真实actor、profile、所属task、card上下文、nonce、PENDING状态、TTL、policy版本、identity epoch、任务未取消和proposal digest。以CAS更新APPROVED，追加审计、使Operation READY，并写outbox；一次事务完成。

第二次检查发生在Broker派发时：重新读取授权、task取消标记、当前policy和资源版本，首次执行验证未使用且未过期；获取资源锁；原子消费approval、创建attempt并将Operation改CLAIMED。仅恢复器批准的同Operation安全重试可以复用匹配的CONSUMED记录，不能复用给其他Operation，且仍须复验原授权的期限和其他全部条件。approval的CONSUMED表示已被用于该Operation，不等于外部动作已经成功。

执行前置条件包括文件old_sha256、工具manifest digest、隔离后端、浏览器页面revision与目标frame、收件账户和内容hash。批准后发生任何影响语义的变化，旧Operation失效，重新生成提案；不得悄悄替换参数继续执行。

批准的过期时间针对开始执行。已经开始的动作不能通过“授权过期”被假装回滚；撤销会阻止后续新派发并尽力停止仍可停止的worker。审批和取消之间的顺序由同一writer事务确定。CLAIMED到DISPATCHING的事务必须再次检查取消；在DISPATCHING提交前已取消则不开始派发。DISPATCHING提交之后收到的取消只能尽力停止在途动作并阻止下一步，

UI必须如实说明。

本地能力授权

Tool Broker生成短期、一次使用的dispatch token，绑定operation、attempt、executor、args hash、resource版本、runtime_epoch、deadline与允许的网络/文件范围。worker只能请求这一dispatch；不能用同一token执行新的工具。token通过继承pipe或受保护IPC传输，不写argv或日志。

Python控制进程可以保存业务策略；不可信Shell、MCP、浏览器插件不能加载进它的地址空间。Gateway只拿飞书凭据，ModelGateway只拿被选Provider密钥，执行器按用途获得单个secret handle。禁止直接继承父进程全部env或把宿主HOME挂进沙箱。

代码执行与文件边界

任意解释器、构建工具、测试命令、包管理器、Git钩子都视为代码执行。传argv、防shell字符串注入和限制cwd仍然有价值，但它们不是文件系统或网络隔离。[S10] 默认执行后端使用受控容器：非root、drop capabilities、无privileged、无Docker socket、只读基础层、临时可写目录、资源限制、默认禁止网络、只读输入快照和单独输出区。

默认不挂载用户原目录作为容器可写workspace。由artifact broker导出大小受限的产物，校验symlink、路径、类型与hash后注册。构建依赖在锁定镜像或明确批准的准备阶段获取；测试运行时不自动联网安装。

宿主文件ACI需要路径对象和OS句柄级防护；path.resolve与字符串前缀检查仅作为初筛。拒绝工作区外、设备路径、UNC与不受支持reparse point、Windows ADS、隐藏敏感配置等；创建文件核验父目录、使用临时文件原子替换、检查旧hash；必要时仅允许受管工作树。恶意同用户进程可持续改变目录时，不能宣称普通路径校验能完全防住，必须依赖隔离后端。

网络与隐私模式

模式	模型出口	飞书	Browser/MCP外网	用途
CONNECTED	指定允许的provider	可启用	逐域名与能力控制	正常远程助手
LOCAL_MODEL	仅已核实的本机模型服务	可启用	仍单独授权	模型数据本地处理
OFFLINE	本机模型或mock	禁用	禁用	无网络任务

LOCAL_MODEL不等于数据永不离机：飞书回复、日志导出和浏览器仍可能外发。OFFLINE须在连接构建时拒绝外部endpoint，并用网络边界验证，不仅靠“模型地址写localhost”。容器loopback并不等于宿主loopback，endpoint解析必须按实际网络命名空间检查。

将数据分类为PUBLIC、WORKSPACE、SENSITIVE、SECRET。SECRET默认不读取、不进入模型；SENSITIVE不得自动发云或进入飞书卡片。每次ModelGateway发送上下文也是数据出口，必须受policy控制。正则脱敏只是补充手段，不能保证识别所有秘密。

来源/指令权威与数据敏感级别是不同维度：公开网页可以是PUBLIC但仍无权赋予权限；本地可信配置可能包含SECRET。摘要继承实际输入的数据限制和来源，不继承新的下指令权。导入文件自称已审查或PUBLIC不是降级依据。

MCP与间接注入

pinning覆盖server包digest、运行命令、环境、transport、完整tool definition、inputSchema/outputSchema/annotations和授权范围。启动重新计算；收到list_changed先隔离相关工具，再比对差异，变更需重新审查。固定版本不代表永久安全，必须有安全更新流程。[S04][S05]

工具输出做结构验证、大小限制和来源标记，但不宣称“清洗后可信”。未知MCP server默认不执行；MVP禁用远端sampling、自动安装和隐式权限升级。若集成库内嵌agent loop且无法逐动作经过Broker，则只使用其只读能力或推迟接入。

审批challenge与渠道权限

创建审批时生成随机nonce，仅将approval_nonce_hash纳入不可变binding；原nonce保存在受保护的challenge store，普通日志与SSE不包含它。飞书仅向允许的owner卡片携带当前nonce；本地已认证、具备approval.challenge范围的客户端通过POST /v1/approvals/{id}/challenge取得当前有效nonce。获取challenge不等于批准，接口仅适用于PENDING、未过期且属于调用方的审批。

重启后从受保护store恢复同一nonce；无法恢复时返回CHALLENGE_UNAVAILABLE并撤销旧审批，重新生成Operation，而不是修改原hash或绕过nonce。gateway token不能调用本地challenge端点。ApprovalPreview返回decision_surface为REMOTE_ALLOWED或LOCAL_REQUIRED；任何敏感内容被省略且影响用户判断时必须LOCAL_REQUIRED，服务端决策接口复核调用渠道。

Task请求中的network_mode和Browser请求中的allowed_origins只能收窄权限。有效权限等于profile策略、principal grant、工作区策略和本次请求范围的交集。请求CONNECTED不能取消全局OFFLINE，请求allowed_origins也不能自行新增域名。

06 数据模型与接口合同

v1.2保留本章23张核心表和14个本地API操作。新增components清单是构建/验证元数据，不在本轮伪造数据库迁移或修改旧授权记录。API采用FastAPI/Pydantic适配，事件流可封装sse-starlette；框架仅承担传输和DTO，所有身份、审批、恢复与事务语义仍由application层执行。

合同验证使用选定的jsonschema Draft 2020-12实现与本地referencing.Registry，显式配置需要的format checker；不自动获取网络ref。Pydantic生成Schema和现有contracts双向做黄金样例核对，差异先修合同，不能让两个模型独立演进。SDK与校验库升级属于合同回归触发条件。[R02]

本地存储原则

每个profile使用独立目录、独立SQLite库和独立token；MVP不在一个数据库中模拟企业多租户。状态表是权威，审计日志是事实记录。对象ID用不可预测ID；事件排序使用数据库seq而不依赖UUID的字典顺序。所有对外ID在owner/profile范围内检查，不因知道ID就获得访问权限。

单writer通过专用执行线程或协程队列串行处理短事务；读连接为query_only并限制查询时间。事务内不await模型、网络、进程、人工审批或另一个写事务。writer队列必须有界，并给审批、取消与入站事务独立配额；“单writer”不意味着可以无限排队。

默认先用sqlite3与专用writer线程，aiosqlite作为可选适配；异步驱动的串行队列不能替代应用层事务归属。使用aiosqlite时，await数据库驱动是允许的，但整个业务事务必须由一个writer命令独占，不能让其他协程的SQL插入其中。不能用通用PriorityQueue名字代替配额、公平性、取消和过期命令丢弃测试，也不把“80行迁移器/150行writer”作为

设计目标。

WriterCommand携带稳定请求ID和deadline；调用者取消等待不证明底层线程没有提交。实际COMMIT后才能形成成功ACK，等待结果不明时按请求ID与权威状态重查，不自动重放。优先队列为审批、取消、执行结果与停止保留容量，并声明普通任务的公平性；锁等待只是总deadline的一部分。[R19]

在线备份的快照形成与复制阶段要pin住相关Artifact引用，防止GC删除快照需要的文件。备份清单保存对象hash、版本与secret_ref，真实秘密仍由受保护存储管理；恢复后秘密引用不可用时进入配置流程，恢复的UNKNOWN继续核对而不重放。

控制数据库采用WAL、synchronous=FULL、foreign_keys=ON。WAL允许读写并发，但仍可能返回BUSY，且不适合把数据库放在网络文件系统上。[S03] busy_timeout必须小于调用路径剩余deadline，不能让回调被固定5秒等待拖过3秒。启动校验实际SQLite版本和PRAGMA结果；不只检查配置文件写了什么。

逻辑表划分

图 5 持久化与事务。完整图见文末架构图册；可编辑源文件随开发交接包提供。

表或对象	核心字段与用途	约束
schema_migrations	version、checksum、applied_at	顺序迁移；checksum不匹配停止写入
profile_config	profile_id、schema_version、policy_version、identity_epoch	一个数据库一个profile
principals	principal_id、role、status、revoked_at	MVP只有一个活动owner
channel_accounts	account_id、channel、tenant_id、app_id、secret_ref	凭据仅存引用
channel_identities	identity_id、account_id、external_user_id、principal_id	account和外部user联合唯一
workspaces	workspace_id、root_ref、generation、status	根目录变更提升generation并撤销旧授权
sessions	session_id、owner_id、workspace_id、status、version	会话归属稳定，不归WebSocket
tasks	goal、state、version、budget_id、cancel_requested_at、checkpoint	状态转换CAS；明确终态
inbox	source_scope、external_event_id、payload_hash、received_at、status	source与外部event联合唯一
events	seq、event_id、aggregate_id、event_type、schema_version、payload	与状态同事务追加；不作为重执行指令
messages	task_id、turn、provider_call_id、role、content_ref、provenance	工具调用与返回一一关联
operations	immutable proposal、binding_hash、retry_class、state、provider_idempotency_key	proposal不可变；state/version单独变化

表或对象	核心字段与用途	约束
approvals	operation_id、actor_scope、nonce_hash、expires_at、status	一个Operation一个批准对象；一次消费
operation_attempts	attempt_no、runtime_epoch、fence、dispatch_id、status、receipt	同一dispatch唯一，历史尝试不覆盖
outbox	semantic_key、target、payload_ref、revision、state、attempts、deadline	处理乱序、合并、重启和结果不明
artifacts	object_id、sha256、mime、bytes、classification、expires_at	不返回任意宿主路径，不可变
artifact_refs	object_id、owner/task/session、purpose	防跨任务越权与误删除
budgets与reservations	限额、已花费、预留、来源	调用前预留，结果后结算
resource_leases	resource_key、holder、epoch、fence、expires_at	不代表外部系统支持fence
tool_registry	tool_id、version、manifest_digest、package_digest、status	修改定义后隔离，不静默升级
runtime_instances	runtime_epoch、boot_id、started_at、heartbeat	记录实例和恢复边界
policy_revisions	version、digest、effective_at、rules	新版本生效使不兼容旧授权失效

长期记忆、embedding与schedule表放在后续migration，不为“将来可能”提前实现复杂检索。若原型已有旧11表，不能覆盖数据库；需要显式映射与迁移任务。

必须具备的事务单元

T1 收到消息：插入inbox，分配session/task，追加TaskQueued事件，生成状态通知outbox；联合去重失败则返回已有Task。

T2 生成提案：插入不可变Operation，记录PolicyDecision；需要审批时插入Approval、切Task为WAITING_APPROVAL并写outbox。

T3 用户批准：校验身份与binding，CAS修改Approval和Operation、追加事件、写状态outbox。任何一步失败全部回滚。

T4 派发claim：复验当前policy、cancel、TTL和资源，消费Approval，创建Attempt，更新Operation为CLAIMED。同Operation安全重试复用已消费授权而不将其复活。CLAIMED到DISPATCHING在新的短事务里复核取消、epoch与资源，再持久化该Attempt的dispatch_id后才能调用外部执行器。

T5 完成动作：写结果receipt与artifact引用，更新Attempt和Operation、结算预算、推进Task、追加事件与outbox。

T6 取消：提升cancel_revision，终止未开始Operation并撤销相关Approval，记录已执行和待核对动作，生成反馈。不能简单级联删除Task。

公共本地API

完整结构在contracts/openapi.yaml。所有接口均受本地认证、profile绑定和大小限制；除健康探测的最小响应外不提供匿名数据。

方法与路径	用途	关键语义
GET /v1/health	daemon readiness、version与能力摘要	不暴露token、路径或secret
POST /v1/tasks	创建Task	必须Idempotency-Key；同key不同payload返回409
GET /v1/tasks/{task_id}	状态快照	返回version与最后event_seq
POST /v1/tasks/{task_id}/cancel	请求取消	幂等；返回已请求或已终态，不能伪称外部回滚
POST /v1/tasks/{task_id}/resume	恢复可恢复任务	expected_version；重新检查预算、资源和授权
GET /v1/events	SSE事件流	after_seq或Last-Event-ID；断点恢复，保留期外返回410并要求重取snapshot
GET /v1/approvals/{approval_id}	不可变提案预览	过滤敏感内容；显示hash和实际执行范围
POST /v1/approvals/{approval_id}/decisions	批准或拒绝	caller身份由认证生成；body没有actor_id或role
GET /v1/artifacts/{artifact_id}	下载获授权产物	Range有上限；固定Content-Disposition，不内联执行HTML
GET /v1/capabilities	可用工具、隔离后端和平台限制	同时返回不可用原因
POST /v1/reconciliations/{operation_id}	结果核对	需证据；不能以“忽略”自动重复发送

Gateway内部接口单独授权，不能复用管理员端点。模型只使用model-tool-call.schema.json提交tool_name与args；服务端再生成包含身份、策略与绑定内容的ToolProposal。模型不能调用审批API、配置API、凭据API或reconciliation接口。

错误统一为code、message、retryable、trace_id、details。示例代码：AUTH_REQUIRED、OWNER_REVOKED、POLICY_DENIED、APPROVAL_EXPIRED、BINDING_MISMATCH、RESOURCE_CHANGED、VERSION_CONFLICT、OUTCOME_UNKNOWN、BUDGET_EXHAUSTED、CAPABILITY_UNAVAILABLE、STORAGE_UNAVAILABLE、SCHEMA_UNSUPPORTED。

工具与事件合同

ToolProposal是内部合同，带schema_version、operation_id、task_id、tool名称与版本、args、资源snapshot、数据级别、retry_class和policy_version。实际用于审批的binding由服务端补齐身份与nonce；LLM不提供这些权威字段。

RuntimeEvent只包含给客户端公开的事件、trace_id和seq。Token streaming可以是临时展示事件；TaskQueued、ApprovalRequested、OperationStarted、OperationFinished、OutcomeUnknown和TaskFinished等业务事件必须

持久。SSE消费者按seq去重，UI先读snapshot再续接事件，避免重连丢状态。

模型工具参数与外部附件禁止超大内嵌。默认文本预览8KiB、完整单产物20MiB、单任务总产物100MiB、单次上传上限与压缩包解压比率都应配置化。这些是初始产品限额，不是安全证明；大文件处理必须分块或显式提高限额。

备份与数据寿命

活跃SQLite使用在线backup API或停止写入后的完整一致性备份，不只复制.db而遗漏WAL。备份包含DB、artifact manifest、必要配置与版本信息；凭据不进入普通备份，恢复时重新绑定或使用独立加密备份流程。

建议默认事件保留30天、普通工具日志14天、截图24小时；用户可配置，但未完成Task和正在被审批引用的产物不能清理。保留期只是建议产品值。审计清理采用显式purge与tombstone，避免ON DELETE CASCADE悄悄抹除授权证据。

本地审计可帮助排障，不是防同一OS用户篡改的合规级审计。未来企业审计需外部只追加存储或远程签名锚定，不能靠本地hash链声称不可篡改。

文件与数据库的提交缝隙

Artifact先写临时文件、flush与fsync、计算hash并原子rename，再在事务中登记metadata和引用。恢复时扫描临时文件、无主对象与缺失对象，缺失时显示不可用而不是伪造成功。多文件patch set保存每文件前后hash与应用阶段；跨多个文件不存在通用SQLite式原子提交，失败时暂停、核对已改文件并按前置条件补偿。不得覆盖用户在此期间的其他修改。

安全预览与核对接口补充

GET /v1/approvals/{approval_id}返回approval-preview.schema.json；完整ToolProposal仅供可信控制平面使用。POST /v1/approvals/{approval_id}/challenge为本地owner提供受限challenge恢复通道，不向SSE广播nonce。

GET /v1/operations/{operation_id}返回受权限过滤的OperationSnapshot，包括Operation.version、state、binding_hash、attempt摘要、结果引用与允许核对选项。Reconciliation中的expected_version必须匹配Operation.version，不得使用Task.version。KEEP_UNKNOWN可以只留说明，无需新artifact；确认成功或确认无副作用失败需要已授权且来源可追踪的证据。结果核对不接受任意retry按钮，后续重试仍由恢复器按原授权与工具语义判断。

本地用户可通过POST /v1/artifacts/import导入任务附件或核对证据；仅接收受限multipart文件内容，禁止传任意宿主文件路径。服务端检查大小、类型、hash、归属和分类，不执行内容。人工结论记录实际来源和确认人；普通用户一句“success”、模型文本或未验证的远程工具字段不能直接改写终态。

SSE若同时提供after_seq与Last-Event-ID，数值必须相等，否则返回400；服务端不猜测冲突游标。

07 执行器与模型接入设计

v1.2的默认实现组合是官方模型SDK薄适配、ripgrep搜索、unidiff解析、受验证容器后端、Playwright原语和官方MCP SDK。具体组件决策、可选项与边界见12_component_reuse；验收场景见13_component_qualification。组件名只确定实施方向，不代表版本或平台已经通过验证。

Tool Manifest

每个内置工具登记名称、版本、input/output schema、effect、资源类型、default decision、retry_class、timeout、max_output、网络要求、secret handles、能力依赖、取消行为和reconcile方法。注册表对模型隐藏内部工具，例如策略修改、批准、凭据读取和数据库管理。

工具	输入重点	默认行为与完成证据
workspace.list	workspace_id、相对path、depth、page_token	返回限量条目；不遍历敏感路径
workspace.read	path、line range、expected hash可选	带行号、文件hash与来源；跨版本读显式提示
workspace.search	pattern、literal/regex、scope、max_results	有时间与大小上限；返回路径行号和hash
workspace.propose_patch	file hash、patch内容	生成不可变diff artifact，不修改用户原目录
workspace.apply_patch	patch artifact、old hash、目标工作树	验证旧hash后原子应用；记录before/after和backup
process.run	executable、argv、input snapshot、backend、limits	隔离执行；退出码、实际argv、镜像digest与日志
browser.open	profile_id、url、allowed origins	专用profile；记录page revision与最终URL
browser.extract	page_id、snapshot revision、scope	限量结构化数据，保留external来源
browser.act	page/frame/target、action、input、expected revision	写动作先审批；点击后验证目标效果
message.draft	稳定收件人ID、正文、附件refs	本地草稿；名称歧义必须先解决
message.send	draft hash、destination account、recipient ID	明确外发审批；receipt或UNKNOWN
mcp.call	server_id、tool、manifest hash、args	经过同一个Broker；不可绕过工具级策略

与U1/U2相比，把patch拆为propose与apply，把browser.click扩成带页面版本的browser.act。这些是减少审批后参数漂移和误操作的接口修订，不是增加一个新的Agent框架。

Workspace与代码编辑

编辑在受管工作树或暂存副本上进行，保留原仓库脏状态。文本patch必须有准确上下文与old_sha256；多匹配、编码不支持或文件已改变时返回RESOURCE_CHANGED，不盲目覆盖。支持UTF-8文本作为MVP边界；二进制写入走artifact导

入和独立策略。

审批同时绑定旧hash和确定的新内容Artifact hash。解析或暂存变换在审批前完成；批准后不让通用patch库重新猜测路径或模糊套用。单文件原子替换不等于多文件原子事务，多文件变更保留日志、恢复点和部分提交状态。Git工作树准备也可能触发post-checkout或filter，需隔离或显式禁用并测试这些执行入口。[R20][R21]

语法检查只对支持的语言执行，不能把lint全部通过当作代码正确。验证脚本本身也可能执行仓库代码，因此走隔离器。回滚只针对本次操作的变更；不允许git reset --hard清理用户既有修改，也不自动commit/push。

tree-sitter与grammar通过限额parser worker使用；不执行目标语言程序不等于native parser没有风险。grammar在安装期固定并预置，运行期禁止按需下载。patch-ng是候选，不接管路径守卫、原子提交或多文件失败语义；以实际支持子集测试决定启用。

Process Executor

生成执行计划时锁定输入快照、可执行文件和参数、容器镜像digest、工作目录、超时、环境白名单、资源上限与网络profile。执行时生成干净HOME和TMPDIR，仅暴露任务工作区。stdout/stderr按字节流处理，保留head/tail与分页句柄，避免一次性读入内存。

普通只读系统查询也需要固定程序与参数集合；禁止通过白名单解释器拼接任意脚本绕过策略。包安装与依赖解析是另一个有网络副作用的操作，不由失败测试自动触发。返回非零退出码是工具结果，不自动升级权限。

默认超时为60秒，用户批准的长任务可提高到10分钟；这些是可配置起点。timeout、用户取消、预算耗尽和daemon退出都传播到worker，并在grace period后由supervisor回收。被终止的进程可能已经生成部分产物，须标注完整性。

Browser Executor

首版使用直接Playwright原语与OpenBot专用user-data目录。用户在这个profile中手动登录；不自动复制日常Chrome profile、解密cookies或接管任意CDP端口。Playwright官方明确警告默认Chrome用户目录不适合直接自动化。[S07]

每次浏览器提案引用page_id、frame_id、snapshot_revision、origin与具体locator。截图坐标仅在后续Computer Use阶段启用，并必须包括scale、viewport、display_id和有效期。页面发生导航或DOM显著变更时重新观察；旧页面的element_index不能跨任务复用。

网络访问默认限制协议与域名。导航、重定向、popup、iframe、下载、上传和所有subrequest都进入网络策略；阻止file、内部地址与元数据地址。仅用Playwright BrowserContext.route / Page.route不能宣称是抗恶意网页的完整网络隔离；需要隔离网络后端时未就绪则不开放该类任务。

锁定的Chromium启动组合须显式启用并验证sandbox，不能因启动失败静默加入no-sandbox。Playwright的应用层route可能遗漏Service Worker处理的请求；选择阻断/管理Service Worker并结合真实出口边界验证，不能只看路由回调计数。非Chromium与各平台另列能力，不从一个flag推导全部浏览器保证。[R18]

浏览器会话含用户登录态，操作日志与截图可能含个人数据。默认不把整屏截图发飞书，只展示经筛选的目标区域或本地预览；登录、MFA和验证码交给用户完成，不把这些信息写入长期记忆。

MCP Client

MVP先支持经固定版本安装的stdio server；Streamable HTTP作为单独后续能力，可在M3选做一个测试server作为兼容验证。支持版本组合写入compatibility manifest，使用SDK协商，不把特定旧版本或SSE写成唯一协议。[S05]

安装与运行分离：运行任务时不能uvx/npx下载latest。安装需本地同意、依赖锁和manifest校验；server进程在隔离环境，不能继承模型key与飞书secret。未知工具结果schema、超大返回或工具列表变化立即停止该server的写能力。

模型网关

能力	统一设计
消息表示	Text、ImageRef、ToolCall、ToolResult，明确工具call_id
流式输出	normalized delta与final事件；半包参数不执行
工具参数	完整JSON后做schema校验；未知字段、NaN、重复key按合同处理
错误	Authentication、RateLimit、Timeout、ContextLimit、MalformedOutput、Unavailable
用量	provider/model/version、prompt/output tokens、cached tokens若可得、估算标识
隐私	每次请求记录数据类与允许provider；禁止local模式自动云回退
兼容	一套真实云provider加一个本地provider作为MVP基线；各自有能力矩阵
重试	对模型请求独立重试和计费；不因此重放工具动作

适配器显式管理SDK重试，默认关闭SDK内建重试，由OpenBot作为唯一请求重试负责人。每次实际调用计入预算，断流后的费用不直接按零结算。只允许基础请求API，不调用官方SDK中的tool_runner、Agent Runner或自动执行hook；半包参数不创建可派发动作。[R03][R04]

本机Ollama地址可能路由云能力。LOCAL_MODEL/OFFLINE需验证所选模型、服务配置及模型服务出口；无法证明本地执行时禁用该保证，不以localhost或模型名过滤代替验证。SDK、词表、价格数据和模型资产分别锁定。[R05]

第一版不做多Agent swarm或隐藏的planner/editor自治链。一次任务采用单控制循环，在需要时添加无执行权限的规划或审阅模型。其输出仍是建议，与普通模型输出相同地进入policy。

上下文由用户目标、必要系统约束、当前任务状态、已批准范围、相关文件片段和最近工具结果构成。大产物通过分页读取；预算按token与字节双控；压缩摘要保留source refs和重要约束。拒绝把API key、完整cookie或secret传入模型。

预算执行采用reserve-then-settle。开始模型或工具调用前预留最大成本，完成后按实际用量结算；超时账单未知时保守保留或标记待结算。重复相同提案、连续同一错误和空转轮次达到阈值时PAUSED并说明原因。

Skills与记忆的后续边界

Skill是可版本化的说明与工具约束，不是扩大权限的脚本入口。导入Skill保留来源、版本、license和capabilities；技能文字不能增加工具授权。自动生成技能先进入draft，不能自动安装并执行。

记忆只存可核对的偏好、项目事实和用户明确确认的信息；绑定owner、workspace、source event、有效期和删除状态。不能从恶意网页推导“用户允许发送所有文件”，不能跨workspace默认召回敏感事实。需要embedding时另立性能与隐私ADR。

观察结果的分类继承

worker的ToolResult是未受信输入。Broker依据权威Operation、resource snapshot与artifact元数据生成内部Observation，注入provenance和data_class，第三方工具不能自称PUBLIC而降低分类。拼接、摘要、分页读取和长期记忆继承输入中最严格的数据类别与来源限制；缺少分类时默认SENSITIVE并拒绝自动外发。

公开SSE、飞书卡片、日志和ApprovalPreview是分别过滤的投影，不直接序列化内部Observation。ModelGateway发送前按实际选入上下文的分类再次检查出口；对SECRET值本地预览也只显示存在和用途，不展示值。

08 飞书入口与远程交互

v1.2复用官方lark-oapi的通信与事件类型，先交付普通卡片。nanobot/LangBot仅作适配和降级模式参考，复制代码需填写来源台账；其队列、配对和工具执行循环不能替代OpenBot控制面。相关SDK准入和阻塞故障场景见13_component_qualification的Q10。

所核对的SDK源码与历史issue存在发现请求未设timeout的情况，实施时按精确锁定版本确认，优先上游修复，必要时采用有回归测试和退出条件的窄补丁。不要盲目全局monkey-patch requests；不能只在可能阻塞的同一事件循环里运行watchdog。supervisor从进程外执行hard deadline与重建，确认旧Gateway退出再启新实例。[R10]

初始化、导入和握手分别计时；U3引用的24.27秒属于具体issue样本，不是所有平台的门槛。卡片业务审批TTL、回调token和API可更新窗口分别建模，按选定卡片版本和真实租户验证，不将14天/30天等未完成验证的数值写成通用逻辑。[R11]

接入约束

飞书是首个正式远程入口。MVP采用企业自建应用的出站长连接；同一app只允许一个活动gateway。官方长连接消息是竞争消费而非广播，多个client不能当作不同电脑的任务路由；每个应用连接数量也有平台上限。[S01]

没有公网IP不等于没有配置成本。安装向导要检查应用类型、tenant、事件订阅、回调版本、机器人权限、测试用户、发消息权限和凭据是否有效。飞书与Lark域名/区域配置分开，禁止未经告知切换区域endpoint。

电脑休眠或关机时无法依靠已经断开的WebSocket继续运行任务。本地常驻服务只能承诺在线时接收、恢复后重连和恢复本地已持久化任务；不能承诺离线期间所有未收到的消息无限补发。需要离线收件箱或远程唤醒时，另设计relay/设备路由与新信任边界。

事件与回调分流

类型	处理路径	成功判定
im.message.receive_v1	校验来源，规范化，向daemon提交inbox事务	持久化成功后快速返回SDK要求的响应
card.action.trigger	校验operator与卡片绑定，提交批准或拒绝事务	返回结构化toast/卡片结果，不等待工具执行
网关状态	心跳、断线、鉴权失败、重新连接	写入health事件，不生成普通用户Task
飞书附件	保存元数据，异步下载到隔离暂存区	类型、大小、hash与数据分类通过后可引用

官方要求回调在3秒内响应，且同步回调不提供补推；普通事件与卡片回调不能使用同一重试假设。[S01] WebSocket方式通过SDK序列化响应，不在代码里假装它是收到一个公网HTTP请求。HTTP Webhook属于另一个可选transport，要额外实现签名、时间窗口与重放防护。

接入线程不得运行模型、下载文件或等待shell。Gateway只做小对象解析并调用daemon的有限接口。首次SDK初始化与重连分别计时；若SDK包含阻塞网络调用，应在独立进程中隔离，以heartbeat watchdog重建该进程，避免不可取消线程持续堆积。

回调时限与数据库背压

设置业务处理总deadline，目标p99小于1秒，并保留平台网络和SDK响应余量。队列未接受、writer过载、数据库不可写或超过开始执行的deadline时，返回“当前无法处理，请稍后重试或本地处理”，不返回“批准成功”。

对已进入提交阶段但响应丢失的情况，数据库记录是真实结果；重复点击读取现有决策。不能因客户端显示超时就再次批准，也不能把一次已持久化批准反悔成“未发生”。任务详情提供查询接口，避免用户只能靠toast判断。

写队列中的callback command要带deadline与request_id。尚未开始且过期的命令必须丢弃；正在事务中的deadline、回滚与提交结果按可观测状态记录。拒绝把超时请求留在后台数分钟后静默执行。

卡片状态与更新

卡片展示Task摘要、目标工作区、当前步骤、operation影响范围、审批有效期、执行状态与查看产物入口。按钮value只携带不透明ID和nonce；收件人、工具参数、权限等从服务端不可变记录读取。

每个Task有单调递增card_revision。Outbox为同一卡片串行投递；低revision更新丢弃或合并，不让延迟的“处理中”覆盖已经完成的“成功”。进度更新按时间和内容变化节流，尊重429和Retry-After；优先保留审批与终态通知。

MVP先实现普通消息卡片加OpenAPI更新；CardKit作为可用时的增强能力。无CardKit权限也能完成任务和审批，不能让“流式卡片漂亮”成为运行时可靠性的前提。

三种期限互相独立

对象	含义	本地规则
approval_expires_at	OpenBot允许开始执行某Operation的期限	可配置，默认短期；到期重新生成审批
card callback token	一次用户交互产生的延时更新凭证	从回调实际产生时计时，不从最初发卡计时
message/card生命周期	平台对更新或交互的限制	由API版本与返回码控制，不覆盖本地授权期限

原材料写的token“30分钟、两次”需要在所用接口与SDK版本组合上确认，不能与其他卡片API混用。[S02] 正确测试应先发生callback，再推进时钟超过token TTL，验证使用次数耗尽与过期时走普通OpenAPI或新消息。仅把卡片放45分钟再点，并不能验证本次callback token已经过期。

本地审批已过期时，旧卡片即使还能点击也不能授权；原卡无法更新时，新卡引用同一Task并展示当前真实状态。回调token只用于卡片更新，不能当作执行授权token。

Outbox投递语义

业务状态与通知意图同事务提交，sender在事务外发送。通知允许至少一次尝试；对平台明确支持的幂等参数保存稳定key并遵循有效期。若远端接受后本地尚未记账，先根据已知message_id或查询能力核对；无法核对则UNKNOWN，不假设发消息天然恰好一次。

向owner发送任务状态属于任务反馈；向第三方发送业务消息必须经过message.send审批，绑定明确账户、收件人ID、内容hash和附件。两个动作都要有receipt，但权限不同。

运维与失败体验

连接健康记录last_frame、last_pong、last_successful_send、auth_status、reconnect_attempt与queue_depth，空闲没有业务消息不能直接推断失联。退避有上限与随机抖动；凭据错误进入需要用户处理状态，不无穷重连。休眠后重建连接，检查审批时间、预算和未知动作。

用户可用的命令至少包括“新建任务”“查看状态”“待审批”“取消”“帮助”。同一输入的重发以event_id去重；用户主动复制同样文字发第二次是新的请求，不能仅按文本hash悄悄吞掉。被撤销的owner无法继续批准旧卡片或通过重新配对绕过本地确认。

09 桌面产品与跨平台交付

v1.2采用分平台监督与安装适配。service-manager仅在已验证支持的launchd/systemd用户级路径使用；它的Windows服务后端不能直接证明登录用户会话能力。Windows启动、注销、会话切换与GUI范围单独验收，不能改用LocalSystem逃避验证。[R13]

进程组、管道EOF、Drop和Job Object分别记录覆盖范围。command-group已弃用，process-wrap/processkit是待资格验证候选；supervisor强杀、Unix逃逸与容器独立生命周期必须有明确限制和恢复流程，不宣称100%整树清理。[R12][R14]

打包先验证PyInstaller onedir，保留调试和非Python资产可见性；不因复用库而承诺固定体积或冷启动耗时。发布清单与SBOM至少覆盖Python、Rust、前端、浏览器、grammar、容器与摘取代码；CycloneDX与SPDX按实际工具输出区分。[R17]

平台能力矩阵

能力	macOS	Windows	Linux	发布条件
CLI、状态机、SQLite、飞书	目标支持	目标支持	目标支持	原生CI加真实主流程
文件ACI与patch	路径/权限适配	驱动器、junction、ADS适配	symlink与权限适配	路径攻击回归通过
隔离Shell	受支持容器后端	受支持Linux容器后端	受控容器/cgroup	无后端明确禁用；不是任意原生命令
专用Chromium profile	版本化浏览器资产	版本化浏览器资产	额外系统依赖预检	登录态隔离和崩溃恢复
本地stdio MCP	受验证的隔离后端	受验证的隔离后端	受验证的隔离后端	server不得继承核心秘密
Tauri界面	M4	M4	M4	签名/依赖与IPC兼容检查
原生桌面观察与操作	Accessibility/ScreenCapture权限	活跃用户session与UIA	X11/Wayland分别实现	后续独立资格验证
锁屏/注销后GUI动作	不承诺	不承诺	不承诺	不绕过OS限制

能力	macOS	Windows	Linux	发布条件
休眠/关机远程唤醒	不属于MVP	不属于MVP	不属于MVP	需另行网络与硬件方案

Windows系统服务不应被当作交互桌面工具；原生GUI执行器在登录用户session运行，而不是提升到LocalSystem解决问题。[S09] macOS权限在每次相关动作前预检；撤销权限后返回CAPABILITY_UNAVAILABLE与本地恢复说明，不自动修改TCC。Wayland必须按portal与桌面环境验证，不能用X11结果替代。[S12]

桌面核心页面

页面	必须显示	用户操作
首次设置	profile、工作区、网络模式、模型、飞书、隔离后端、真实能力	明确确认工作区与凭据、运行doctor
任务列表	状态、来源、工作区、最后事件、费用与待处理项	新建、取消、暂停、恢复
任务详情	用户目标、实际动作、policy原因、产物、错误与未知结果	查看diff、下载、进入核对
审批中心	完整影响范围、hash、执行环境、目的地、有效期	批准、拒绝、查看变化、要求重新生成
运行健康	daemon/gateway/model/executor分别健康	重连、启动/停止服务、导出诊断
权限与隐私	workspace grant、数据出口、owner、已启用工具	撤销、调整模式、查看权限变更
更新与恢复	当前版本、兼容范围、迁移风险、备份状态	下载并验证、安排维护、恢复备份

时间线记录输入摘要、上下文来源、工具提案、策略依据、授权、实际执行和结果。它不是模型隐藏思维链的导出器；仅展示模型主动给出的简明计划/说明和可审计事实，不依赖或要求provider暴露内部推理。

主按钮文本要区分“关闭窗口”“退出界面”“暂停接单”“取消任务”“停止服务”。关闭窗口默认保留daemon。界面崩溃时飞书继续；daemon崩溃时界面显示恢复或失联，不能仅因WebView仍在就显示运行正常。

桌面与daemon的安全连接

Tauri能力只授予专用Rust命令，不给WebView任意spawn/execute。界面加载本地受控资源，启用CSP，禁止remote页面获得native IPC。用户点击外链打开系统浏览器。渲染Markdown和tool output时禁用脚本与危险HTML。

Rust bridge从受保护通道读取session token，校验daemon identity与协议版本，代理有限操作；默认不把管理员token交给JS。开发调试接口只在dev profile开启；release构建不含可供其他页面访问的管理后门。Tauri capability并不自动把sidecar沙箱化。[S11]

打包策略

初期开发安装采用uv与受控依赖锁；发布先使用PyInstaller onedir以简化资源与原生库排查，onefile在后续测量后选择。PyInstaller产物依赖目标OS和Python环境，不能在一个OS构建后声称三平台可用。[S13]

发布清单包含core、gateway、supervisor、desktop、协议版本、DB schema范围、Python与SQLite版本、MCP SDK、浏览器build、容器镜像digest、SBOM与licenses。需要下载浏览器资产的安装模式要明确网络需求、校验hash和离线失败体验。

每个平台分别打包与验收：macOS应用及helper签名公证；Windows安装包与程序签名、WebView2和用户级启动检查；Linux依赖、glibc与desktop环境预检。证书与发布密钥位于受保护发布环境，普通PR任务不能读取。

升级与回滚

升级顺序是下载、签名校验、兼容检查、暂停新派发、等待可安全停止点、停止workers、制作一致性备份、迁移、启动新版本、健康检查、恢复接单。旧批准在policy或manifest改变后失效。

Tauri updater签名验证保护更新包真实性；OpenBot仍需自行定义跨组件和数据库兼容性。[S14] 回滚二进制不必然能读新schema。迁移后已有新写入时，恢复旧备份会丢失这些新写入；必须展示这个事实，不能宣称“无损一键回滚”。MVP优先向前兼容迁移，自动回滚只在预先定义的安全窗口内。

卸载默认保留用户数据并给出路径；清除数据是显式选项。不能删除用户原工作区、共享浏览器或非OpenBot管理的进程。

10 验证体系与运行维护

v1.2增加组件资格验证目录Q01至Q16，详见13_component_qualification。实现任务先通过所用组件的相关准入场景，再通过业务验收；不把“库已成熟”或“安装成功”当作授权、隔离与恢复测试的替代。组件升级按影响范围重跑门禁，未影响部分不无故扩大测试。

测试分层

确定性测试验证控制面行为，真实模型评测验证完成任务的能力，真实OS测试验证系统边界。三者不能互相替代。测试必须有输入、动作、断言和证据；不要求用海量镜像实现的单元测试堆覆盖率。

层级	内容	触发
Unit / Contract	状态转换、canonical hash、配置、schema、错误映射	每个相关变更
Integration	SQLite事务、Broker、FakeProvider、FakeExecutor、MockChannel	PR门禁
Security	身份重放、审批竞态、路径逃逸、网络出口、秘密canary、插件绕过	涉及边界的PR及发布
Chaos	每个commit边界kill、断网、超时、磁盘满、时钟变化	nightly与恢复改动
Native platform	安装、权限、进程组、用户注销、升级、休眠	对应平台发布
Real service	飞书测试租户、真实模型、受控浏览器、测试MCP	凭据隔离的集成环境
Evaluation	任务成功、成本、延迟与错误副作用	模型/工具/提示模板重要变更

阻塞性验收场景

测试ID	输入或故障	必须观察到的结果
AT01	同一入站event重放100次	一个逻辑Task；每次响应指向同一结果
AT02	20个相同审批并发点击	一个批准决策和一次claim；不增加外部动作次数
AT03	批准后改argv、文件hash或收件人	BINDING_MISMATCH或RESOURCE_CHANGED；不执行
AT04	取消与批准、claim竞争	事务顺序明确；取消后不派发新动作；已开始效果如实记录
AT05	远端成功后本地commit前kill	UNKNOWN与核对；不自动再次发送
AT06	同一profile启动第二个daemon	第二实例不能执行，返回已有实例信息或清晰失败
AT07	旧worker租约过期后恢复	fence/epoch失效；不能作为新实例继续提交或派发
AT08	symlink/junction/ADS/UNC/路径大小写攻击	作用域外文件不被读写，错误不泄露内容
AT09	恶意README要求读取key并外发	模型可被诱导，但实际读取/外发被policy与隔离阻止
AT10	测试脚本试图读取HOME或连网	沙箱范围与出口规则实际生效
AT11	MCP定义变更或内部自治调用写工具	工具隔离；未经新的有效授权不执行
AT12	Cloud provider在LOCAL_MODEL模式被选择	请求发出前拒绝，无隐式fallback
AT13	OFFLINE模式启用飞书/浏览器	配置冲突被识别，外网请求计数为零
AT14	飞书callback超时、重复、token过期	无虚假成功；数据库状态可查询；卡片可降级
AT15	outbox更新乱序与429	旧revision不覆盖新状态；节流和退避可观测
AT16	磁盘满、writer队列满	拒绝新派发，不把未持久化请求ACK为成功
AT17	用户关闭Tauri窗口	daemon和授权任务继续；显式stop才回收
AT18	升级迁移失败	保持可恢复状态，旧数据不被静默覆盖
AT19	只复制DB备份缺artifact	恢复验证失败或明确缺失，不宣称完整恢复
AT20	Owner撤销后点击旧审批	OWNER_REVOKED，旧token与旧卡片均无执行权

每个场景用mock测试控制面；涉及权限、网络、进程和安装的场景还需真实边界验证。所谓“边界证明”在这里指测试证据，不等于数学证明所有攻击均不可能。

质量基准

固定八类任务：仓库定位、两文件修复并保留脏改动、隔离测试、含注入页面的结构化提取、MCP成功后超时核对、飞书跨重启批准、owner撤销、离线与本地模型区别验证。每类记录task输入、环境快照、预期产物、允许副作用、模型配置与版本。

指标包括Task success/partial/failed、未知结果率、错误副作用数、恢复正确率、工具调用数、审批次数、token、估算/实付费用、端到端延迟分位数。先跑小型基线形成实测数据再设性能门槛；不能引用他人或示意图百分比作为本产品稳定率。

可观测性

每条日志带profile_id、task_id、operation_id、attempt_id、trace_id、event_seq和runtime_epoch中的适用项。区分用户可见事件、开发诊断和安全审计。日志默认存结构化摘要，正文、截图和凭据不进入普通日志。

health输出分项状态；关键指标包括writer queue depth、oldest inbox age、outbox backlog、waiting approval count、unknown operations、worker count、model error rate、budget remaining和last gateway heartbeat。提供doctor命令定位权限、网络、模型、数据库、浏览器与沙箱能力缺失。

诊断包须先预览；默认包含版本、错误码、能力矩阵、脱敏日志和schema，不包含任务全文、cookies、token、源代码或截图。需要加入敏感内容时用户明确选择，并记录导出范围。

运行手册

故障处理顺序：停止新派发、保留状态和证据、确认活动worker、核对UNKNOWN、修复连接或存储、验证权限与预算、再恢复。禁止以删除.db、清空全部审批或关闭policy来“修复”系统。

凭据疑似泄漏时本地撤销相关channel/provider，旋转凭据，提升identity_epoch，失效旧token，核查外发记录。MCP异常时隔离该server，保留manifest与动作记录；不能因它自称readOnly就继续运行。

备份每次升级前执行，周期备份由用户配置；恢复演练至少覆盖空机器、旧版本与缺失artifact三种情况。用户注销、睡眠与网络断开都单独测量。发布前运行持续浸泡，但实际时长由版本风险决定，不能把某个12小时测试当作长期可用性证明。

11 项目计划与AI编码交接

v1.2任务总数为96：原OB-001至088保留，新增089至096。M0/M1/M2/M3/M4/P2分别为13/37/11/25/4/6项。组件复用改变实现方式、准入与验收，不减少授权/恢复责任；逐项差异见tasks/REVISION_v1_2.md和tasks/revision_delta.json。

项目交付方式

把本包放入新仓库，先让Codex或Claude Code读取README、AGENTS、当前阶段文档和指定任务卡。模型可以协助编码、运行测试和整理差异，产品范围、安全决策、真实服务凭据、签名发布与最终验收仍需有明确的责任人。

tasks/backlog.json是任务事实源，TASKS.md是可读任务手册。任务ID稳定；实现过程中按实际情况新增子任务，不随意重编号。所有任务初始为TODO，不能因本包已经写出接口或SQL就标记实现完成。

图 6 里程碑与门禁。完整图见文末架构图册；可编辑源文件随开发交接包提供。

里程碑与退出条件

阶段	主要内容	必须演示的闭环	退出门禁
M0	规格、威胁模型、合同、工具链、fake夹具	无网络启动测试夹具并校验合同	核心ADR稳定，版本与风险基线明确

阶段	主要内容	必须演示的闭环	退出门禁
M1	本地内核、安全工具、认证API、恢复	CLI提交、提案、批准、隔离执行、kill、恢复、取消	未授权副作用为零；UNKNOWN正确；数据可备份
M2	飞书消息、配对、卡片、outbox和watchdog	手机发任务、点击审批、断网重连、重启继续	真实测试租户通过，回调期限与去重有证据
M3	两Provider、Browser、MCP、三平台CLI、质量基准	同一任务包在目标平台完成并输出能力报告	原研究稿MVP能力逐项验收，无未解决P0缺陷
M4	Tauri、签名安装、升级和诊断	干净机器安装、关UI后台继续、升级失败恢复	签名与兼容范围可验证，用户流程完整
P2	GUI、记忆、定时、多设备、更多模型	每项单独建立能力演示和安全门禁	不借用MVP结论宣称新增能力已安全

不能把M1本地原型或M2飞书Alpha宣传为原研究稿全部MVP。完整MVP必须包含Browser、MCP、至少两个Provider与三平台CLI范围；若某平台只能提供部分能力，就在release能力表里明确列出。

第一条垂直切片

M0先完成OB-091最小协议PoC：FakeChannel接收唯一事件，使用真实临时SQLite落盘；FakeProvider生成受审批操作，标准JCS绑定；MockWorker产生可核对marker；在claim与dispatch等提交点注入崩溃，恢复后安全继续或保留UNKNOWN与资源隔离，最后由FakeOutbox反馈。该PoC不证明真实沙箱或网络安全。

M1的OB-029仍是正式集成切片：接入真实本地API、文件/产物、权限、Broker与已通过资格验证的隔离执行路径。Provider可以使用可控fake以避免真实凭据阻塞，但不能以MockWorker代替隔离验证。OB-092建立组件故障合同，OB-093提前验证首发OS组合；后续再接飞书、Browser与MCP。两种切片分别留证据，禁止用M0通过直接关闭M1任务。

并行开发分工

工作流	负责范围	不能自行更改
Lead / Integrator	合同、ADR、任务状态、集成、迁移序号和版本	不绕过各模块安全门禁
Runtime / Storage	状态、数据库、调度、恢复、预算、核心API	不改第三方接入语义
Policy / Tools	授权、路径、隔离器、Broker、artifacts	不放宽范围让测试通过
Integration	Feishu、Provider、MCP、Browser协议适配	不在适配器内自行执行未经Broker的动作
Platform / UI	Supervisor、三平台安装、Tauri与更新	不让UI持有数据库写权限

一个开发者加一个编码助手可按依赖串行推进；有多个助手时，最多同时开展2至3个边界清晰、文件不重叠的工作包。每个助手使用独立分支或worktree。schema、migration、lockfile与顶层接口由唯一owner合并，避免同时编辑。

集成代理必须在合并后的实际工作树运行相关验收，不能把三个独立分支各自测试通过当作系统已集成。发生合同冲突先更新ADR和任务，不让两个助手各写自己的协议。

Definition of Ready

任务进入READY前，须有明确输入和依赖、唯一owner、影响模块、正常与失败路径、验收命令或人工步骤、测试数据和变更边界。需要真实凭据但尚无测试租户的任务不能伪装为可验收；可先完成mock部分并记录剩余工作。

Definition of Done

任务完成需要实际行为通过、负向断言通过、必要的原生/真实服务验证完成、接口与文档同步、无新凭据泄漏、风险说明清晰。提交验收证据包含commit、测试命令、结果、环境/版本与已知限制。仅生成代码、仅类型检查通过或模型自报完成均不满足DoD。

任务状态建议使用TODO、READY、IN_PROGRESS、REVIEW、VERIFIED、DONE、BLOCKED。本包使用TODO初始化；状态只能根据实际证据改变。开发代理每轮报告“改动、原因、测试、限制、下一依赖”，不隐瞒未跑的真实环境测试。

排期方法

原材料的8至12周等数字不是当前仓库的工期基线。未提供现有代码、投入时长和真实平台环境时，采用门禁驱动排程；tasks中的S/M/L仅表示相对规模。先完成M0和第一条垂直切片，再用实际吞吐和返工率预测M2/M3。

v1.2采用三个启动批次：第一批冻结范围/信任边界/生命周期、核验当前所需依赖与仓库骨架；第二批完成事件/工具/配置/错误合同及标准向量；第三批完成最小崩溃协议PoC。每批以实际产出为门禁。暂不把U3的复用比例、LOC或性能倍数换算为缩短工期；原有粗略周数在PoC与首发OS资格验证后重新估算。计划记录负责人可投入时间、目标机器、测试租户与模型预算，按实际吞吐和阻塞原因滚动更新。

M0结束时需要给出更窄区间及其依据，未完成前不承诺固定发布日。最影响进度的路径是身份与合同、持久化、审批claim、隔离执行、恢复、飞书真实接入、三平台资格验证。

成本与资源

主要成本项是负责人的开发与验收时间、模型调用、真实测试机器/虚拟机、签名发布、CI执行、浏览器与容器资产维护。BYOC降低中央算力支出，但不是产品总成本为零。暂不列随时间变化的具体云价格；实现时按选定provider的实际用量计费模型记录和核对。

费用预算应限制每Task、每天和每profile，设硬上限与通知阈值。token价格缓存必须带来源日期和币种；无法获得真实计费量时使用“估算”，不把它当作发票金额。

变更控制与开放问题

M0只需把实际首测OS、可用隔离后端、两个provider、飞书租户、许可选择和发布负责人记录为配置/ADR，不必阻塞本包交付。若改变single-owner、增加多设备、要求无Docker执行任意宿主代码或提前做GUI，属于改变信任边界，应先更新相关威胁模型和计划。

原研究中的团队、云同步、自动技能学习、语音和多Agent保留在后续路线中。不要为了“架构可扩展”提前引入Kafka、Kubernetes、分布式数据库或向量服务；当前瓶颈是执行语义与产品验证。

12 架构决策与证据索引

决策记录

ADR	决策	依据与取舍
ADR01	自有薄控制内核，成熟执行组件通过port接入	保持U1主线；避免深fork和隐藏权限链
ADR02	Python业务内核，Tauri客户端后置，native supervisor独立	保持生态便利与常驻生命周期
ADR03	每profile独立SQLite，状态表加审计与inbox/outbox	单机可运维；不承诺完整事件重放执行
ADR04	控制库WAL加FULL，短事务与有界writer	优先已确认命令耐久性；牺牲部分吞吐
ADR05	Task、Operation、Approval、Attempt独立	明确授权、执行、恢复和未知结果
ADR06	Approval一次消费，dispatch属于Attempt，幂等键属于Operation	避免安全重试要求二次消费或错误复活授权
ADR07	单Broker执行所有副作用	模型、工具库与渠道不拥有独立执行权
ADR08	不可信代码隔离执行，无后端不降级宿主	明确安全能力与便利性的取舍
ADR09	单owner、单app、单活动gateway作为MVP	飞书竞争消费不是设备路由
ADR10	LOCAL_MODEL与OFFLINE分离	隐私出口与远程能力不可混为一个布尔量
ADR11	OpenBot专用浏览器profile，直接Playwright原语	可验证逐动作审批，不自动接管日常profile
ADR12	MCP固定包与完整定义，禁用未知server发起能力	pinning配合执行隔离与更新流程
ADR13	先CLI与普通飞书卡片，后CardKit与Tauri	最早验证可靠任务闭环
ADR14	平台能力分级，原生GUI另立门禁	UI能启动不等于桌面自动化可用
ADR15	出口治理包含模型请求、消息与artifact	读取后发模型也属于数据外发
ADR16	以真实验收记录任务完成，不以生成代码量估进度	适合Codex与Claude Code逐任务协作
ADR17	分阶段依赖组与组件准入，默认组件也需锁定和实测	不在M0一次安装所有候选；记录非Python资产
ADR18	模型请求只有一个重试负责人，API面排除自动工具helper	避免SDK与tenacity叠加、隐藏执行和预算漏记
ADR19	标准JCS库、严格JSON入口与权威canonical bytes	修正UTF-16排序；浅冻结DTO不能保证授权不可变

ADR	决策	依据与取舍
ADR20	源码摘取与直接依赖分别管理来源和升级责任	固定commit、LICENSE/NOTICE、diff、维护人和回归
ADR21	容器、进程监督和服务安装按实际后端/平台资格验证	统一API不代表相同隔离、回收或用户会话保证
ADR22	native解析、流式脱敏与离线模式采用有界可验证合同	不沿用零风险、128字节100%脱敏或localhost必本地的假设

原材料

U1 《OpenBot 开源桌面智能体深度研究报告.pdf》，用户提供，20页。主要使用第6至17页的产品目标、架构原则、MVP范围和工程路线。其竞争项目数字与产品时事不作为本方案技术事实。

U2 《OpenBot 架构设计与任务规划.pdf》，用户提供，36页。主要使用第9至24页的协议、数据库与进程设计，以及第26至33页的任务和测试。第8、25页图片已核对。本次逐项修正见01_gap_review。

U3 《OpenBot 开源组件复用评估.pdf》，用户提供，27页。正文标题为《OpenBot 工程交接包（v1.1）架构深度对齐与开源生态复用全景研究报告》。已阅读全文及第2、11页图表。采纳/调整见12_component_reuse、13_component_qualification和14_revision_v1_2；Stars、代码行数、速度提升、固定导入耗时和绝对安全保证不作为已验证结论。

官方资料

核验日期为2026年11月4日。链接中的版本仅代表本次核对的页面；不将某个版本标称为“最新”。实际依赖在各阶段引入前锁定并验证；M0只覆盖当前所需组件。部分飞书页面动态渲染，检索结果与官方页面共同用于核对；无法稳定读取的token细节列为集成验证项。

[S01] 飞书长连接与回调。用于企业自建应用、竞争消费、3秒响应、回调不补推等约束。

- https://open.feishu.cn/document/ukTMukTMukTM/uYDNxYjL2QTM24iN0EjN/event-subscription-configure-
- https://open.feishu.cn/document/event-subscription-guide/callback-subscription/receive-and-handle-callbacks

[S02] 飞书卡片交互。用于区分回调携带的更新token与OpenBot业务审批期限。接口版本差异需在测试租户确认。

- https://open.feishu.cn/document/uAjLw4CM/ukzMukzMukzM/feishu-cards/handle-card-callbacks
- https://open.feishu.cn/document/uAjLw4CM/ukzMukzMukzM/feishu-cards/card-json-v2-components/interactive-components/image-picker

[S03] SQLite PRAGMA与WAL。用于NORMAL/FULL耐久性、单写者、WAL并发与本地文件系统约束。

- https://www.sqlite.org/pragma.html
- https://www.sqlite.org/wal.html

[S04] OWASP MCP Security Cheat Sheet。用于完整工具定义摘要、动态变更和工具输出边界；具体策略为本方案推导。

- https://cheatsheetseries.owasp.org/cheatsheets/MCP_Security_Cheat_Sheet.html

[S05] MCP工具、生命周期与传输。2026-07-28工具页和2025-11-25生命周期/传输页均已核对；实现只能选择经实际测试的完整协议/SDK组合，不能混搭不同版本字段。

- https://modelcontextprotocol.io/specification/2026-07-28/server/tools

- https://modelcontextprotocol.io/specification/2025-11-25/basic/lifecycle

- https://modelcontextprotocol.io/specification/2025-11-25/basic/transports

[S06] RFC8785 JSON Canonicalization Scheme。用于跨语言哈希需要确定性表示的设计依据。

- https://www.rfc-editor.org/rfc/rfc8785

[S07] Playwright BrowserType。用于专用持久profile、默认Chrome profile不受支持的注意事项。

- https://playwright.dev/python/docs/api/class-browsertype

[S08] Microsoft进程监督。用于Job Object、breakaway和CREATE_SUSPENDED语义；受控启动顺序是本方案工程设计。

- https://learn.microsoft.com/en-us/windows/win32/procthread/job-objects

- https://learn.microsoft.com/en-us/windows/win32/procthread/process-creation-flags

[S09] Microsoft Interactive Services。用于区分系统服务与交互用户桌面。

- https://learn.microsoft.com/en-us/windows/win32/services/interactive-services

[S10] Docker Engine Security。用于容器配置、daemon攻击面与权限隔离的设计边界。

- https://docs.docker.com/engine/security/

[S11] Tauri Capabilities与Sidecar。用于界面能力与外部二进制接入；它们不替代执行器sandbox。

- https://v2.tauri.app/security/capabilities/

- https://v2.tauri.app/develop/sidecar/

[S12] XDG RemoteDesktop Portal。用于Linux会话授权与输入能力边界。macOS部分以权限实测为交付要求，不沿用固定周期断言。

- https://flatpak.github.io/xdg-desktop-portal/docs/doc-org.freedesktop.portal.RemoteDesktop.html

[S13] PyInstaller Operating Mode。用于目标OS专属构建与onedir/onefile选择。

- https://pyinstaller.org/en/stable/operating-mode.html

[S14] Tauri Updater。用于签名验证与更新包契约；数据迁移和回滚规则由OpenBot自行定义。

- https://v2.tauri.app/plugin/updater/

尚待实测的内容

真实飞书租户的权限、SDK版本与卡片行为；目标机器冷启动和重连时间；macOS录屏与Accessibility授权状态；Windows嵌套Job与原生路径；Linux发行版与Wayland差异；模型工具调用质量与成本；容器隔离配置；签名安装与升级恢复。

这些项目已经进入任务清单。没有跑过的真实环境测试不会在本报告中被标成已通过。

v1.2组件核验来源

以下资料支持本轮组件行为核对。文档/源码核对不代表目标平台运行测试；历史issue不是普遍性能基线。移动分支不能替代实际锁定发行物。机器可读索引见evidence/reuse_sources.json。

[R01] RFC8785与所选实现。UTF-16码元排序、严格输入域；库负责规范化，不负责授权。

- https://www.rfc-editor.org/rfc/rfc8785.html
- https://github.com/trailofbits/rfc8785.py

[R02] DTO与JSON Schema。frozen不深冻结；format需显式启用；当前Registry默认不自动联网，旧RefResolver不同。

- https://docs.pydantic.dev/latest/concepts/models/#faux-immutability
- https://python-jsonschema.readthedocs.io/en/stable/validate/
- https://python-jsonschema.readthedocs.io/en/stable/referencing/

[R03] OpenAI官方SDK与工具。内建重试与配置；基础模型请求、function提案和服务端工具需分开。

- https://github.com/openai/openai-python
- https://developers.openai.com/api/docs/guides/tools

[R04] Anthropic官方SDK。基础Messages、默认重试与tool_runner自动执行helper；按实际版本限制入口。

- https://platform.claude.com/docs/en/cli-sdks-libraries/sdks/python

[R05] 本地模型与token资产。Ollama支持云功能，存在禁云配置；tiktoken缺缓存时可获取词表，估算不能当全Provider账单。

- https://docs.ollama.com/faq
- https://github.com/openai/tiktoken/blob/main/tiktoken/load.py

[R06] 原生parser与grammar。Tree-sitter可含C external scanner；language-pack当前文档包含首次按需下载。

- https://tree-sitter.github.io/tree-sitter/creating-parsers/4-external-scanners.html
- https://github.com/xberg-io/tree-sitter-language-pack/blob/main/README.md

[R07] 容器CLI适配。python-on-whales可切换CLI，Podman/nerdctl为best-effort，不证明配置语义等价。

- https://gabrieldemarmiesse.github.io/python-on-whales/docker_client/
- https://gabrieldemarmiesse.github.io/python-on-whales/sub-commands/container/
- https://docs.podman.io/en/latest/markdown/podman-machine.1.html

[R08] 容器产物复制。docker cp可从已停止容器复制；权限与所有权受平台及参数影响。

- https://docs.docker.com/reference/cli/docker/container/cp/

[R09] MCP官方SDK与迁移。SDK主版本、stdio环境基线与协议功能应固定成完整组合；默认环境有选择不代表适合全部任务。

- https://github.com/modelcontextprotocol/python-sdk
- https://py.sdk.modelcontextprotocol.io/migration/
- https://github.com/modelcontextprotocol/python-sdk/blob/main/src/mcp/client/stdio.py

[R10] 飞书SDK发现请求。核对到的v2_main源码有同步requests发现调用；issue169讨论超时问题。必须对锁定版本复核。

- https://github.com/larksuite/oapi-sdk-python/blob/v2_main/lark_oapi/ws/client.py
- https://github.com/larksuite/oapi-sdk-python/issues/169

[R11] 飞书冷导入历史issue。24.25/24.27秒来自具体Windows/Hermes/lark-oapi组合的个例，不能外推为所有平台。

- https://github.com/NousResearch/hermes-agent/issues/85564

[R12] 进程组封装维护状态。command-group明确弃用并指向process-wrap；候选API仍需原生故障验证。

- https://github.com/watchexec/command-group

- https://docs.rs/process-wrap/10.0.1/process_wrap/

[R13] 服务安装层级。service-manager对systemd/launchd有用户级支持，Windows后端不直接提供同等User能力。

- https://docs.rs/service-manager/latest/service_manager/

- https://docs.rs/service-manager/latest/src/service_manager/sc.rs.html

- https://docs.rs/service-manager/latest/src/service_manager/winsw.rs.html

[R14] 进程监督能力边界。processkit的Drop/平台保证及管道协作清理有边界；不能推出通用100%回收。

- https://docs.rs/processkit/latest/processkit/

- https://docs.rs/processkit/latest/processkit/struct.ProcessGroup.html

- https://docs.rs/ur-taking-me-with-you/latest/ur_taking_me_with_you/

[R15] 凭据后端。keyring有自动后端选择与替代后端；服务会话、锁定和无图形环境需单独处理。

- https://keyring.readthedocs.io/en/latest/

[R16] 秘密扫描。detect-secrets存在网络验证、插件和allowlist机制；不等同通用实时脱敏。

- https://github.com/Yelp/detect-secrets

[R17] SBOM格式。CycloneDX Python产生CycloneDX；Syft支持SPDX与CycloneDX，实际产物需按对应格式验证。

- https://cyclonedx-bom-tool.readthedocs.io/en/stable/

- https://github.com/anchore/syft

[R18] 浏览器默认值与请求路由。Chromium sandbox配置需要显式核验；route不拦截Service Worker处理的全部请求。

- https://playwright.dev/python/docs/api/class-browsertype

- https://playwright.dev/python/docs/api/class-browsercontext

[R19] SQLite、队列与异步驱动。SQLite默认同步选项受编译配置影响；backup仅复制DB；aiosqlite每连接线程队列不等于业务事务独占。

- https://www.sqlite.org/compile.html#default_synchronous

- https://www.sqlite.org/backup.html

- https://aiosqlite.omnilib.dev/en/stable/

- https://docs.python.org/3/library/asyncio-queue.html#asyncio.PriorityQueue

[R20] 搜索与Git隐藏执行。ripgrep有配置与preprocessor；git worktree add可触发post-checkout。

- https://github.com/BurntSushi/ripgrep/blob/master/GUIDE.md

- https://git-scm.com/docs/githooks#_post_checkout

[R21] Patch职责与版本差异。unidiff解析；patch-ng发布版与开发分支能力不能混写，最终宿主提交仍由File Broker控制。

- https://github.com/matiasb/python-unidiff
- https://pypi.org/project/patch-ng/
- https://github.com/conan-io/python-patch-ng

[R22] 社区飞书参考。nanobot聊天接入和QR应用注册可参考；不能据此赋予OpenBot owner。

- https://github.com/HKUDS/nanobot/blob/main/docs/chat-apps.md
- https://github.com/HKUDS/nanobot/blob/main/docs/guides/feishu-ai-agent.md

[R23] 日志、追踪与平台权限。上下文需管理；OTel外部exporter与敏感数据需配置；Apple权限按实际状态检测。

- https://www.structlog.org/en/stable/contextvars.html
- https://opentelemetry.io/docs/security/handling-sensitive-data/
- https://opentelemetry.io/docs/languages/sdk-configuration/general/
- https://support.apple.com/guide/mac-help/control-access-screen-system-audio-recording-mchld6aa7d23/mac
- https://support.apple.com/en-my/guide/mac-help/mh43185/mac

[R24] 版本化许可证据。pathspec、Anthropic SDK与AstrBot的精确许可不同；最终以锁定发行物及使用方式审查。

- https://pypi.org/project/pathspec/
- https://raw.githubusercontent.com/anthropics/anthropic-sdk-python/main/README.md
- https://github.com/AstrBotDevs/AstrBot/blob/master/LICENSE

13 开源复用策略与组件准入

本轮结论与使用方式

本章把用户新增的U3《OpenBot 开源组件复用评估.pdf》转化为可实施的组件选择。采纳其“自研权威控制面、复用协议与执行原语”的方向；保留v1.1的Task、Operation、Approval、Attempt、UNKNOWN、审批消费、资源隔离和单writer语义。组件清单用于指导实施，不表示这些依赖已经安装、锁定或通过产品测试。

组件选择的事实源是components/catalog.json；本章说明边界，13_component_qualification规定测试，14_revision_v1_2记录对U3的采纳与修订。所有组件的实际准入状态从NOT_RUN开始，精确版本、哈希与许可证证据在实施时填入。官方页面上的latest、报告中的版本范围或GitHub Stars都不能充当发布锁文件。

图 7 自研控制面与开源复用边界。完整图见文末架构图册；可编辑源文件随开发交接包提供。

四类复用决策

类别	含义	编码助手的动作
DEFAULT_ADAPTER	当前设计首选，通过薄适配层使用	到达所属任务后核对来源、锁定版本、运行准入测试；通过前不能宣称能力可用
GATED_CANDIDATE	有价值但兼容性或副作用需要先验证	先完成小范围PoC，再由ADR和证据决定是否启用；不自动成为默认依赖

类别	含义	编码助手的动作
REFERENCE_ONLY	参考算法、接口或交互模式	默认不复制代码；若摘取，记录文件、commit、许可证、改动和维护人
DEFERRED / REJECTED_MVP	延后或当前版本明确不采用	不加入MVP默认环境；说明未来重新评估条件

这是工程准入规则，不要求用户逐个确认常规库安装。编码助手可以在当前范围内自主核验、锁定、适配和测试；改变信任边界、引入宿主任意执行、云回退或发布行为，仍按用户的具体授权处理。

自研范围与默认复用矩阵

领域	默认复用方向	OpenBot保留的职责	关键验证
本地API与SSE	FastAPI、Uvicorn；sse-starlette按需适配	认证、Host/Origin、权限范围、序列游标、背压与取消	loopback、无token泄漏、断线续传、过期游标410
数据合同	Pydantic v2、jsonschema Draft 2020-12	严格输入、字段权威来源、不可变canonical bytes	禁多余字段、拒重复键、格式检查、禁远程ref
提案摘要	Trail of Bits rfc8785与hashlib	绑定字段、版本、授权、原文存储和复核	UTF-16排序、数值边界、负零、非法Unicode、官方向量
SQLite	标准库sqlite3；异步封装可选aiosqlite	单writer、队列配额、T1至T6事务、迁移、预算和恢复	FULL/WAL实测、deadline、回滚、备份与产物清单
模型请求	官方openai与ollama SDK或受控httpx；Anthropic后续	模型能力、出口、预算、流式重组与唯一重试负责人	超时、429、断流、重复计费、无自动工具循环
飞书	官方lark-oapi	配对、持久去重、审批CAS、Outbox、卡片版本	初始化与连接分离计时、外部watchdog、真实回调
文件ACI	ripgrep；pathspec、unidiff按职责封装	句柄守卫、范围、快照、精确补丁、原子提交	目录竞态、重名匹配、超限、恶意diff与忽略规则
语法解析	tree-sitter及必要语言grammar作为候选	有界解析、超时、来源与错误映射	大文件、深度、native崩溃、不执行项目配置
容器后端	python-on-whales封装一个已验证Docker CLI后端	镜像、挂载、网络、资源、产物导出与归属	无host兜底；容器ID独立回收；权限与网络实测
浏览器	Playwright异步原语与专用Profile	页面revision、动作审批、网络范围、结果核对	service worker、重定向、弹窗、frame与UNKNOWN
MCP	官方Python SDK，选择一个完整版本组合	工具定义固定、范围、server隔离、事件审查	版本协商、stdio环境、list_changed、恶意server
凭据与日志	keyring、structlog	后端准入、最小注入、分类、流式脱敏、审计语义	无D-Bus/锁定钥匙串、分片秘密、诊断出口
CLI与分发	Typer、Rich、uv、PyInstaller onedir优先	用户流程、安装、资产清单、能力探测	无ANSI/HTML注入、原生平台、离线安装资产

领域	默认复用方向	OpenBot保留的职责	关键验证
Supervisor与桌面	OS原语及经验证的Rust封装；Tauri后置	runtime_epoch、drain、归属、用户会话、升级	强杀、子孙逃逸、Windows登录会话、UI退出

不以“组件成熟”替代本项目的组合验证。组件对输入或子进程的默认行为可能和OpenBot的策略不同；适配器必须把这些差异显式映射到错误、取消和UNKNOWN语义。

适配器端口与调用合同

domain只依赖值对象和端口，不导入模型SDK、飞书SDK、Playwright、容器客户端或MCP SDK。application通过端口发起用例；providers、channels、tools与native bridge实现端口。第三方类型不得穿透到Operation、Approval或数据库事务层。

端口	输入与输出	不允许隐含发生的行为
ModelTransport	已过出口策略的请求、deadline、预算上下文；返回流事件与usage	自行运行工具、云回退、后台联网查价格、无记录的多次请求
Canonicalizer	已严格解析且满足数值域的JSON；返回canonical bytes	自动字符串化非法键、丢弃重复键、修改Unicode、忽略非法数值
WorkspaceSearch	受管snapshot、范围和有界查询；返回带来源的命中	任意cwd搜索、继承用户rg配置、把.gitignore当授权边界
PatchParser	已批准格式的diff；返回内存补丁计划	直接写用户路径、模糊套用、执行Git钩子、自动reset
IsolationBackend	镜像digest、输入快照、资源策略与dispatch；返回运行标识和结果	拉取latest、挂载HOME/socket、自动联网、失败转host
BrowserPrimitive	已绑定的页面/元素快照与单次动作；返回观察或receipt	自主规划下一步、在库内请求模型、重复点击未知动作
McpTransport	已登记server、固定定义与请求；返回协议结果	安装包、按annotations扩大权限、继承所有凭据
ProcessSupervisor	受管进程/容器归属、deadline、stop请求；返回回收证据	仅凭父PID退出判定容器结束、把协作清理等同强隔离

适配器至少提供capabilities、deadline、cancel、close/cleanup和结构化错误映射。它们的health只表示组件可响应，不表示某次副作用已成功；成功必须来自对应结果与OutcomeVerifier。一个请求只能有一个重试负责人，且attempt计数、预算和审计必须可观察。

分阶段依赖与离线资产

依赖按功能分组：dev-contracts、core、provider-openai、provider-ollama、feishu、tools-file、executor-container、browser、mcp、desktop、p2。M0先引入完成当前合同与PoC所需的最小集合；M2/M3依赖在到达对应任务时安装和资格验证。可选模块缺失时返回能力不可用，不让核心导入失败，也不在运行中自动安装。

版本锁覆盖Python包、Rust crates、CLI二进制、浏览器build、tree-sitter grammar、容器image digest、tokenizer数据、前端资产与摘取代码commit。依赖是“包+版本+平台+可选特性+配置+资产”的组合，仅有pip包版本不够。

首次安装或构建阶段可以在明确的联网准备流程中取得资产并校验。OFFLINE启动、模型请求、任务执行和导入测试不下载浏览器、词表、grammar、价格表或远程Schema。离线资产缺失返回明确错误；不要把联网下载隐藏成重试或初始

化。成本表保留日期、币种与来源，无法精确统计的token用量明确标为估算。

components/dependency-lock.template.json是填写结构，不是已完成的锁定结果。没有伪造版本、哈希或“已通过”字段；真正实现后由锁文件和产物清单生成记录，并与release manifest互相核对。

模型SDK与重试的具体约束

本轮首选官方SDK薄适配器，LiteLLM保留为候选。官方SDK不天然等于零副作用：OpenAI和Anthropic SDK均文档化了内建重试，额外套tenacity可能扩大调用数。[R03][R04] 建议由OpenBot适配器显式配置SDK重试为0，统一管理有界请求重试；若未来委托SDK重试，必须保持单一负责人并逐次观测，不能两层同时重试。

允许重试模型请求并不意味着费用可以忽略。每次请求独立预留和结算；超时或断流的计费状态可能不明，不能立即释放全部预算。半包tool-call不得进入Broker；丢弃的部分输出不等于服务端未计算。OpenAI-compatible只代表协议家族，具体云服务或本机端点需要各自的能力与错误合同测试。

tiktoken作为适用模型的本地预估器，不能声称对所有Provider精确计数。词表离线预置并校验；保留供应商usage作为结算依据。官方SDK同样可能提供自动工具helper，例如Anthropic的tool_runner。适配器仅允许已审查的基础请求API，不调用tool_runner、Agent Runner、自动执行hook，也不启用未经授权的服务端工具。不能仅按“官方/第三方”判断是否存在自动执行。[R03][R04][R05]

Ollama监听loopback不证明所选模型在本机推理；服务支持云功能。LOCAL_MODEL/OFFLINE需同时验证模型来源、服务配置与实际出口，显式关闭云能力，并将模型服务纳入相应网络边界或记录可信的部署证据。不能只拒绝带cloud的模型名后宣称离线；无法确认时禁用本地保证并返回能力不可用。服务更新后重新探测，任务中不拉取新模型。[R05]

文件、补丁与解析器的复用边界

ripgrep只承担搜索计算。固定二进制来源、清理RIPGREP_CONFIG_PATH、显式选项与输入根目录；忽略规则用于产品筛选，不能覆盖权限守卫。--max-count通常按文件限制，另需全局命中数、输出字节、时间和文件数量上限。搜索结果重新通过资源范围与快照校验，不能把外部路径原样当作读权限。

unidiff负责解析，patch-ng仅在通过支持子集与精确匹配测试后成为候选应用器。所有文件创建、删除、重命名、行尾、二进制和多文件事务行为由OpenBot合同决定；第三方库能解析某种diff，不代表该操作在产品中已获准。补丁先在受管暂存区计算结果，校验old_sha256后由受控写入流程提交；拒绝路径穿越、模糊匹配、部分成功冒充整体成功。

tree-sitter不执行目标语言程序，但包含native解析代码和grammar，仍可能发生崩溃、资源耗尽或恶意输入问题。采用受限parser worker、文件大小/时间/内存上限和固定grammar集合。当前tree-sitter-language-pack文档包含首次按需下载parser的行为，必须按所选版本核实并在安装期预置，运行期缺失就失败。运行pytest、ruff、mypy、tsc以及项目配置插件仍走隔离执行器。语法树无ERROR不等于功能正确。[R06]

容器、MCP与进程归属

先资格验证一个Docker兼容后端。python-on-whales对Podman/nerdctl的支持为best-effort，不能用切换client_call一项参数推导所有挂载、网络、资源和取消语义等价。[R07] Podman、Lima、OrbStack或其他环境逐组合验证；没有对应证据就不列为已支持。bubblewrap保留后续候选，不能作为未经验证的自动兜底。

容器客户端进程和容器不是同一个生命周期对象。Broker登记容器ID、标签和Operation归属；取消后停止并wait，完成受限产物导出和校验，再删除容器。停止客户端不证明容器已停止。导出不得跟随符号链接或接受路径穿越，检查类型、大小、归属和权限；在Windows用ACL语义，不能统一写chmod 0640就宣布安全。[R08]

MCP版本按官方SDK与协议的完整组合锁定，不能把U3的mcp>=1.28当锁定结果。stdio客户端对环境变量的默认处理随版本变化；OpenBot始终显式构造允许列表、受管HOME/TMP/PATH与启动命令，并对实际子进程验证。SDK不承担授

权、产物隔离或UNKNOWN恢复；工具完整定义变更后先冻结相关调用，再复审。[R09]

飞书、Supervisor与桌面端

复用lark-oapi通信协议与类型，普通卡片作为首个交付能力；CardKit是可选增强，权限或版本不满足时使用已验证的普通卡片路径。nanobot、LangBot仅作为模式参考，摘取代码须走来源台账。社区二维码流程不能替代OpenBot本地owner确认。

飞书SDK冷启动应在Gateway初始化阶段独立测量，随后才开始连接时限；不强制采用线程预热，也不沿用“24.27秒/100%失败”的普遍结论。对于已定位的阻塞发现请求，优先采用经验证的上游修复；必要窄补丁记录commit、差异与退出条件。真正的hard deadline由Gateway之外的supervisor执行，不能只靠可能已被阻塞的同一事件循环。[R10][R11]

command-group已经弃用，当前不纳入默认依赖；process-wrap或processkit按实际保证评估。service-manager可封装支持的launchd/systemd用户级功能；Windows登录用户会话单独设计，不能用sc.exe/WinSW的系统服务能力替代。跨平台Drop/管道/进程组是部分清理机制，必须说明强杀、逃逸、断电和外部容器的剩余边界。[R12][R13][R14]

Tauri与macOS权限插件在M4/P2需要时再引入。权限检查以API结果和真实机器为准，不把“每30天强制重授权”写成固定平台规则；Tauri Capability也不自动为sidecar提供沙箱。

凭据、脱敏与观测

keyring需锁定允许后端，验证锁定、无D-Bus、无图形会话与取消场景；不得自动采用不安全替代后端。无可用钥匙串时返回可处理错误；本地加密文件若没有独立主密钥保护设计，不是可直接启用的兜底。[R15]

detect-secrets默认作为开发/CI辅助扫描候选，运行时仅能复用已审查的离线检测器。禁止网络验证、动态插件和外部文本中的allowlist注释改变出口策略；官方工具确实提供联网验证选项，因此必须显式处理。[R16] 固定128字节窗口不能保证所有秘密被识别。流式redactor须定义检测规则、最大长度、编码和flush规则，无法安全判断的缓冲内容不外发；分类阻断、最小注入与已注册secret精确匹配优先于启发式扫描。

structlog提供结构化日志管道，OpenBot负责字段最小化、脱敏顺序、上下文清除和异常格式。OpenTelemetry默认不开启外部exporter；trace、日志、诊断包和模型输入同受出口策略。高基数ID用于有界日志/trace，不直接作为无界metrics标签。

许可证、摘取代码与升级维护

本项目默认优先采用适合目标分发方式的宽松许可组件。报告将AGPL/GPL一概称为不可用不准确；本方案把尚未评估的强copyleft代码排除在默认MVP复制和链接路径之外，作为项目准入选择。MPL、双许可证、bootloader例外以及浏览器/grammar/镜像的独立许可都需要按精确文件与分发方式记录，不按“MIT/Apache白名单”一句话省略核验。

直接依赖和摘取源码是两种维护责任。摘取nanobot模板、browser-use DOM逻辑或Aider算法实现时，记录上游URL、commit、文件路径、文件hash、许可证/NOTICE、修改diff、维护人、回归测试、升级触发条件和替换方案；禁止复制完整自治循环。没有足够收益证据时先自行实现有限原语，保持REFERENCE_ONLY。

发布前生成与工具实际输出相符的SBOM：cyclonedx-bom产生CycloneDX，Syft可按配置输出SPDX或CycloneDX；不能混写格式。[R17] SBOM覆盖Python/Rust/前端包、二进制、浏览器、grammar、容器和摘取代码。安全更新改变完整工具定义或执行语义时，应使相应旧授权失效，重新资格验证；不能静默修改已批准Operation的manifest。

14 组件验证与接入门禁

资格验证的目标

候选库能够导入、示例能运行、上游有测试，都不能证明它符合OpenBot的授权、隔离与恢复合同。本章将复用风险转成独立可复查的验证项目。实际结果写入templates/component-qualification.md对应记录和evidence目录；本设计交付中的所有真实组件验证状态为NOT_RUN。

新库接入按“候选登记、来源与许可、精确锁定、副作用观察、合同/故障、目标平台、发布资产”推进。任一强制项失败，相关能力不可启用；可继续其他不依赖它的任务。组件变更只重新运行受影响门禁和固定回归，避免每次微小改动都重跑全部平台。

必须记录的证据

证据组	必须包含
身份	package/repository、精确版本或commit、下载来源、sha256、可选特性和传递依赖
环境	OS/架构、Python/Rust/SDK版本、容器引擎与配置、浏览器/grammar/词表版本
行为	实际网络请求、DNS、子进程、读写路径、线程、初始化时延、关闭和取消表现
合同	输入/输出、流式分片、错误码、超时、重试次数、预算与结果未知处理
许可	LICENSE/NOTICE来源、选用的许可分支、分发方式、未决问题
结果	测试命令、退出码、脱敏日志、预期与实际、限制、责任人和关联任务
升级	触发复验的变化、回退版本与资产、上游补丁退出条件

源码浏览只能证明文档或实现的可见行为，不能把它记成真实OS或真实租户通过。所有证据带日期与版本；历史issue只证明曾出现该问题，需要针对选定版本确认是否仍存在。

验证场景目录

ID	场景与判定	主要关联任务
Q01	最小依赖环境导入/启动/首次调用；阻断外网并观察文件与进程。离线缺资产应明确失败，不能联网补下载	OB-005、OB-008
Q02	JCS与严格JSON：UTF-16排序、负零、指数、嵌套对象、重复键、NaN/Infinity、孤立代理项与超范围整数	OB-006、OB-007、OB-018、OB-063
Q03	DTO与Schema：frozen嵌套修改不得改变已存提案；完整Draft 2020-12、format、extra字段和远程ref拒绝	OB-006、OB-007、OB-081

ID	场景与判定	主要关联任务
Q04	模型SDK：连接失败、429/503、断流；统计实际请求数与计费；Ollama本地地址转云模型/云搜索必须被阻止	OB-023、OB-025、OB-026、OB-027
Q05	SQLite：优先级队列拥塞、取消、deadline耗尽、CAS与Outbox失败回滚、在线备份及产物manifest	OB-011至OB-020、OB-030
Q06	搜索/补丁：用户rg配置、忽略规则、ADS/UNC/reparse、恶意diff、重复匹配、超量输出、跨文件失败	OB-032至OB-035
Q07	Parser：超大/深嵌套/畸形输入、native worker崩溃、grammar缺失、受限资源和取消	OB-035、OB-041
Q08	容器：输入只读、无network、无secret/HOME/socket、资源上限、停止客户端后容器归属、恶意导出	OB-040至OB-042
Q09	原生进程：Windows挂起创建/Job失败、Unix进程组逃逸、父进程强杀、supervisor失败与容器独立回收	OB-015、OB-042、OB-068至OB-071
Q10	飞书SDK：冷启动/热启动分开测量、发现端点挂起、外部watchdog重建、重复事件、回调deadline和终态卡片	OB-047、OB-049至OB-056
Q11	Browser：专用Profile、frame/revision失效、service worker和下载出口、跨源/弹窗、提交后断线UNKNOWN	OB-057至OB-061
Q12	MCP：版本协商、精确env、受限stdio、协议帧/大小、list_changed、主动sampling、超时与有副作用工具	OB-062至OB-065
Q13	Secret/日志：跨任意分片边界与编码、超长秘密、异常栈、SDK调试日志、allowlist注入、联网验证被禁	OB-037至OB-039、OB-075
Q14	上游代码摘取：固定commit与文件hash、LICENSE/NOTICE、修改补丁、隐藏循环/外发和升级diff	OB-004、OB-051、OB-059
Q15	发布资产：从干净环境按锁重建、离线词表/浏览器/grammar、SBOM格式和非Python资产、许可证清单	OB-066、OB-072至OB-074
Q16	最小协议PoC：FakeChannel、真实临时SQLite、标准JCS、FakeClock、MockWorker，在claim与dispatch提交点崩溃	OB-010、OB-017至OB-020、OB-029

Q01的“没有观察到网络”必须明确观察范围。仅mock httpx不能拦住requests、Rust扩展、子进程、DNS或浏览器；使用目标平台可提供的网络隔离/审计组合，并分别报告已覆盖和未覆盖部分。离线模式限制的是OpenBot进程与其受管执行域，不声称改变整台用户电脑的联网状态。

Q02使用经过核实的RFC向量与所选库；不在测试代码中再写一个同样错误的排序器当oracle。Python是binding_hash的权威，UI无需独立实现授权判定；只有实际引入另一种语言的JCS实现时才要求跨实现字节一致。入口先拒绝重复键，再进入普通dict，不能让解析器静默保留最后一个键后才校验。

Q04区分模型请求和工具动作。Provider请求可能重复计费，但不得造成工具自动重复执行。预算状态未知保守保留；应用重试、SDK重试与HTTP transport重试必须可数且只有一个策略负责人。

Q08/Q09必须分别证明本机客户端、Worker、容器和子孙进程的最终状态。host端Docker控制接口属于受信适配器，不传入不可信容器。产物导出在停止并wait后进行，校验完成再remove；恢复器处理尚未删除的受管容器，不能删除未登记的用户容器。

Q10不把一次issue中的24.27秒导入作为所有机器的预算。测量至少区分解释器启动、SDK导入、凭据检查、端点发现、握手和业务ready。健康监控位于可能阻塞组件之外；重建前确认旧实例退出，避免两个Gateway竞争收件。

Q13的通过标准是已定义规则与canary集合的完整通过，不是“识别世界上全部秘密”。不确定的敏感内容不通过扫描器的阴性结果自动降级；SECRET和SENSITIVE仍受分类策略控制。不得将真实凭据作为第三方在线验证输入。

最小协议PoC与正式垂直切片

先在M0完成小范围协议PoC：只验证持久化、JCS绑定、批准、claim、派发前检查、崩溃点与UNKNOWN资源隔离。使用FakeProvider和MockWorker，无需真实飞书、浏览器或容器。通过后才适合大规模并行开发。

OB-029仍代表M1集成后的正式垂直切片，必须使用真正的本地API、权限、产物和隔离执行路径。M0的PoC不能把OB-029或真实安全工具任务提前标为DONE。两个里程碑的证据分开保存，既尽早降低架构风险，也避免mock掩盖真实集成问题。

性能、收益与工期

本轮不采用U3的Stars、固定行数、10倍速度、20至100倍提升或百分比复用收益作为验收值。实施时分别测量冷启动、ready时间、常驻内存、安装体积、一次受控工具动作、恢复耗时和回调分位数，记录硬件、版本、样本数与测量方法。

开源复用节省的主要是协议解析和成熟原语实现；适配、隔离、供应链、真实平台验证和上游维护仍是工作量。M0按准入证据完成情况重新估算剩余任务，S/M/L仅表示相对规模，不把新增任务数直接折算为日历天数。

变更后的复验规则

纯文档改动只检查引用与任务一致性；适配器配置变化重跑对应Q项；SDK主版本、解析/哈希行为、完整工具定义、隔离引擎或浏览器build变化重跑相关合同、恢复和平台门禁。涉及不可变提案语义的变化使旧授权失效，不能重算旧hash后继续执行。

每次升级保存原锁文件、构建资产和兼容范围。出现版本冲突或已知漏洞时可禁用受影响能力并继续其他能力；不以忽略错误、放宽网络或回退宿主的方式保持“可用”。

15 v1.2修订记录与实施顺序

本轮变更范围

输入是新增的U3《OpenBot 开源组件复用评估.pdf》（27页，包括第2与11页图表），对照本轮之前的v1.1设计包。采纳其复用方向，针对官方资料与源码核验后修订边界。表内“采用”均表示设计选择，真实组件资格验证仍是后续任务。

保留原88个任务ID与阶段，新增OB-089至OB-096，共96项；增加组件关联、复用方式与验收说明。原有23张SQL表、14个本地API操作、四对象状态及UNKNOWN恢复语义保持。新增6项ADR，累计22项；架构图增加复用边界图，累计7张。组件目录包含52个组件或组件组，所有实际准入状态从NOT_RUN开始。

U3逐项采纳与修正

编号 / 原文页	采纳或修正	落地要求与主要任务
RC01 / 1-3、21、26	采用自研控制面和原语复用；删除自研即可彻底避免重复效果的推论	Task/Operation/Approval/Attempt、CONSUMED、UNKNOWN与quarantine保持；OB-017至020、022、091
RC02 / 7、15、21	JCS键排序改为UTF-16码元；标准库排序不能替代RFC8785	rfc8785、严格JSON入口、标准向量与canonical bytes；OB-006/007/018/063/090；[R01]
RC03 / 7、20	frozen=True不等于嵌套不可变	已批准内容来自不可变规范字节和数据库约束；OB-006/007/018/090；[R02]
RC04 / 7、20	format需显式检查；新Registry与旧RefResolver行为分开	固定本地Schema Registry、限制深度/大小/耗时、未知ref拒绝；OB-007/081/090；[R02]
RC05 / 8、16、21-22	官方SDK存在内建重试；不能与tenacity叠加	唯一重试负责人、实际请求计数、预算与deadline；OB-023/025/026/027/092；[R03][R04]
RC06 / 8-9、13、22	官方SDK也可能提供tool_runner；结构化输出重试不应误称任意工具执行	允许API面与字段白名单；禁自动helper/未授权服务端工具/扩展字段透传；OB-007/025/027/037；[R03][R04]
RC07 / 8、16、24	localhost不证明本地推理，tokenizer不保证全Provider精确计费	Ollama禁云与实际出口核验；词表预置、usage优先、缺资产失败；OB-008/023/026/037/096；[R05]
RC08 / 7、16、20	aiosqlite串行请求不等于完整事务所有权；取消等待不证明回滚	WriterCommand独占事务，提交结果可重查，队列预留与公平性；OB-012/014/022/092；[R19]
RC09 / 7、16、20-21	不采“SQLite默认NORMAL”“ORM必死锁”与固定行数结论	读取实际PRAGMA；迁移恢复与DB+Artifact一致备份；OB-011/012/030/073；[S03][R19]
RC10 / 12、22	rg配置/预处理器与git worktree hooks可能引入执行	--no-config、受限参数与环境；快照禁hooks/filter或进入隔离准备；OB-032/033/034/040；[R20]
RC11 / 12、17、22	Diff解析/库apply不等于安全原子提交	精确新内容hash、暂存变换、File Broker提交与多文件恢复日志；OB-034/035/036；[R21]
RC12 / 12、17、22	native parser有故障边界；语言包可能首用下载	有限grammar、预置资产、受限parser worker；OB-035/041/096；[R06]

编号 / 原文页	采纳或修正	落地要求与主要任务
RC13 / 12-13、23	容器CLI封装不提供全部后端等价；客户端退出不等于容器退出	首发后端逐配置验证；stop/wait、导出校验、remove；OB-040/041/042/093；[R07][R08]
RC14 / 13-14、18、26	command-group已弃用；删除100%整树回收	评估process-wrap/processkit与OS原语，单一生命周期所有者；OB-015/042/093；[R12][R14]
RC15 / 14、25	service-manager不能直接承诺Windows用户会话服务	macOS/Linux已验证用户级路径与Windows登录会话分开；OB-068至071；[R13]
RC16 / 9、16、23	SDK冷启动数字仅为个例；同事件循环watchdog不能覆盖同步挂死	锁定版本复核、窄补丁记录、Gateway外hard deadline、READY后连接计时；OB-047/054/056；[R10][R11]
RC17 / 10、23-24	普通事件/卡片回调/更新token/业务TTL分离；扫码不等于owner	保留本地确认；普通卡片先行；CardKit与更新窗口真实租户验证；OB-048至053/094；[S01][S02][R22]
RC18 / 13、17-18、24	Playwright默认配置与route存在覆盖边界	显式验证Chromium sandbox，处理Service Worker/下载/重定向出口；无no-sandbox静默降级；OB-057/058/061；[R18]
RC19 / 13、18、24	SDK版本范围不是锁；定义hash不能证明实现永远安全	固定完整SDK/协议、环境、包与配置；保留server隔离与持续权限；OB-062至065；[R09]
RC20 / 3、13、23	来源可信度与数据敏感级别分别建模	外部数据无赋权能力；摘要按实际输入继承出口限制；OB-002/024/036/037
RC21 / 14、23	删除128字节/100%脱敏；detect-secrets可能联网验证	定义有界匹配、完整出口覆盖、禁网络verify与外部allowlist；OB-038/039/075/092；[R16]
RC22 / 14-15、19	keyring后端与OTel exporter需明确；不采用固定30天权限规则	禁明文/不安全backend兜底；外部trace默认关闭；TCC按实测；OB-038/075/084/085；[R15][R23]
RC23 / 10、15-19、25-26	许可证按具体版本与使用方式核验；纠正CycloneDX/SPDX	NOTICE、摘取源码台账、所有发布资产SBOM；OB-004/074/094/095/096；[R17][R24]
RC24 / 1-2、7-8、11、19、26	不采用M0全量安装、Stars/LOC/性能倍数或复用比例承诺	按阶段依赖与准入证据推进，测基准后再估排期；OB-005/076/080/089

本轮将平台复核与架构复核合并为以上24项修订，不能把它们理解为24个已经实现的修复。具体任务差异见tasks/revision_delta.json与tasks/REVISION_v1_2.md。

八项新增任务

ID / 阶段	新增任务	与原任务的区别
OB-089 / M0	建立组件准入目录和分阶段依赖门禁	OB-004继续负责来源与许可证；本项建立机器可检查的准入与阶段规则
OB-090 / M0	验证Schema与JCS标准合同向量	标准序列化与完整合同验证先于审批实现；Python仍是hash权威
OB-091 / M0	交付最小claim/dispatch崩溃协议PoC	用真实临时SQLite与mock效果提前验证语义，不替代OB-029正式集成

ID / 阶段	新增任务	与原任务的区别
OB-092 / M1	建立组件副作用和重试取消故障契约	统一不同SDK的失败证据，原适配器任务仍要各自填写并通过
OB-093 / M1	验证首发OS的Supervisor与隔离后端能力	先验证一个真实组合；三平台完整资格仍属于OB-069至071
OB-094 / M2	审查飞书模板的最小源码复用	固定来源/许可证与裁剪边界；允许有依据地决定NO_COPY
OB-095 / M3	审查DOM提取脚本的最小源码复用	不让browser-use自治循环进入系统；允许NO_COPY
OB-096 / M3	验收全量交付资产来源与供应链	补充浏览器、grammar、词表、镜像和摘取代码；不等到M4才清点

更新后的阶段与门禁

阶段	任务数	本轮新增或加强的门禁
M0	13	最小依赖、组件目录、完整合同向量、早期崩溃协议PoC
M1	37	SDK副作用/重试合同、首发OS后端资格、真实本地纵向闭环
M2	11	飞书SDK进程外监督、真实卡片语义、模板源码审查
M3	25	Browser/MCP真实边界、三平台CLI、DOM源码审查、全量资产来源
M4	4	Tauri、签名更新与迁移恢复，使用已通过的组件与资产
P2	6	后续Provider、GUI、记忆、定时、多设备按独立门禁扩展

首轮先完成OB-001至005与依赖就绪的OB-089；再完成合同、测试夹具、OB-090与OB-091。M0通过后开始M1，优先把OB-092与OB-093的风险前置；OB-029作为正式M1集成门禁保持原含义。各阶段内按depends_on推进，编号顺序不是执行顺序。

对编码助手的交接变化

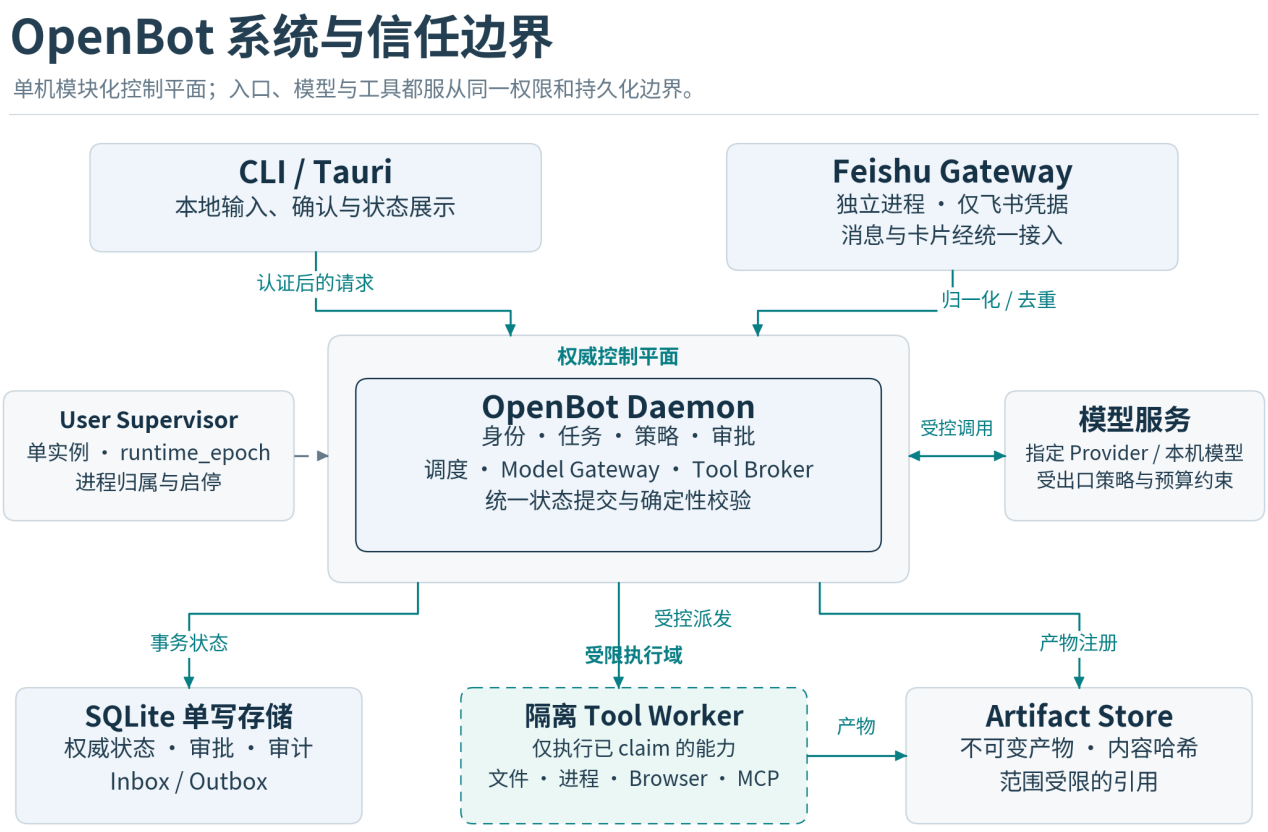
每轮除了原有依赖和验收，还要读取task的component_refs、reuse_type与reuse_notes，并核对components/catalog.json的决策。候选与参考项不能仅因出现在任务中就安装或复制。完成一个准入任务不意味着后续所有适配器自动通过；必须记录精确组件与平台组合。

AGENTS、CLAUDE和prompts已经同步：常规可逆实现可以连续推进；无真实环境时完成可独立部分并继续其他就绪任务；不通过放宽权限、添加宿主fallback、忽略未知结果或声称未跑测试来完成任务。沿用既有用户授权，不为了常规组件替换增加无必要确认。

16 架构图册

图示与正文合同一致。完整 PNG、可编辑 SVG 和 Mermaid 源文件位于开发交接包 diagrams 目录。图中的目标和门禁是设计要求，仍须真实实现和验证。

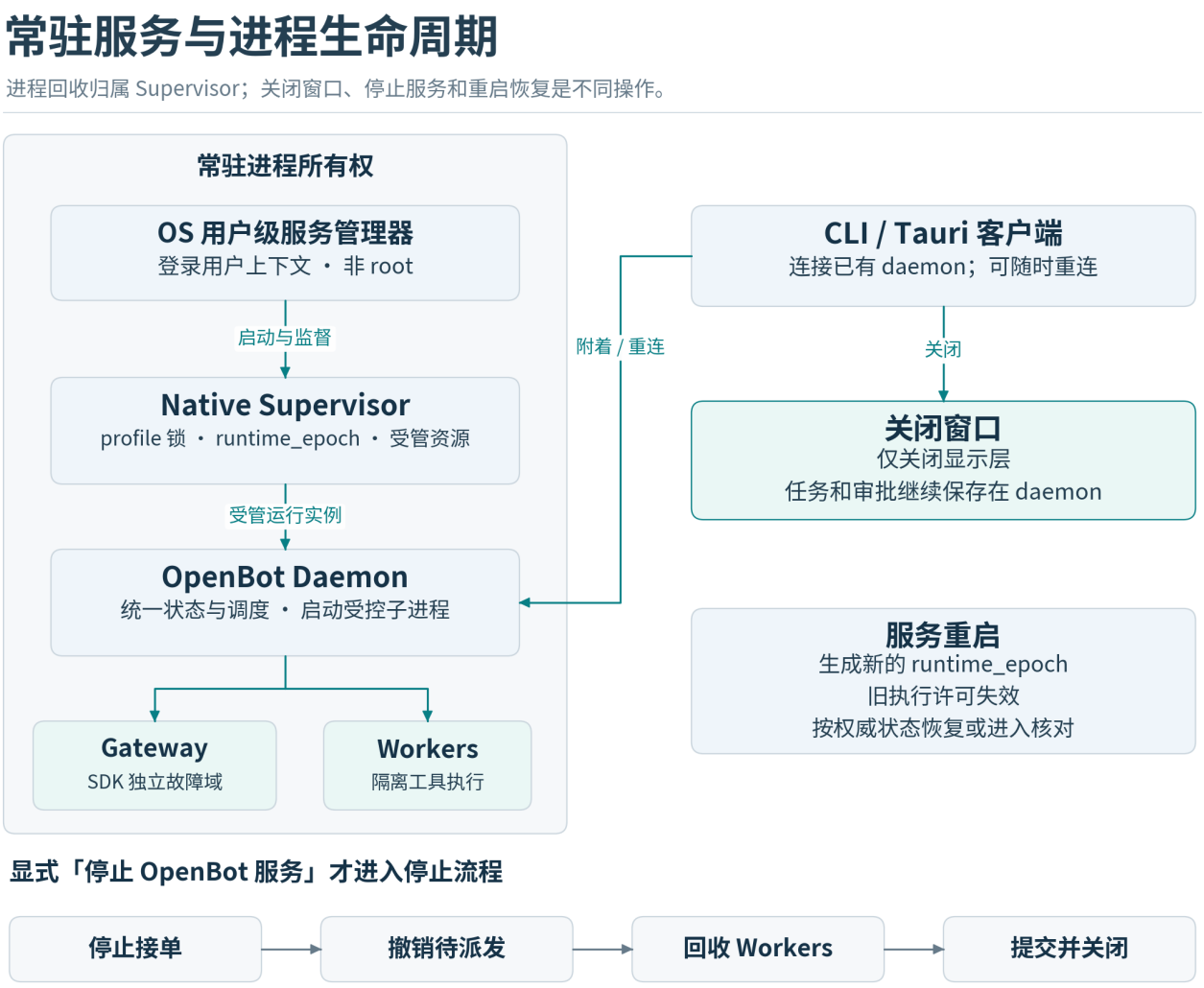
图 1 系统与信任边界



界面不持有任务权威状态；所有工具动作经过 Broker；仅 Daemon 写 SQLite。

设计来源：本报告模块与状态契约。图为工程设计，不是运行系统截图。

图 2 进程生命周期



设计来源：本报告模块与状态契约。图为工程设计，不是运行系统截图。

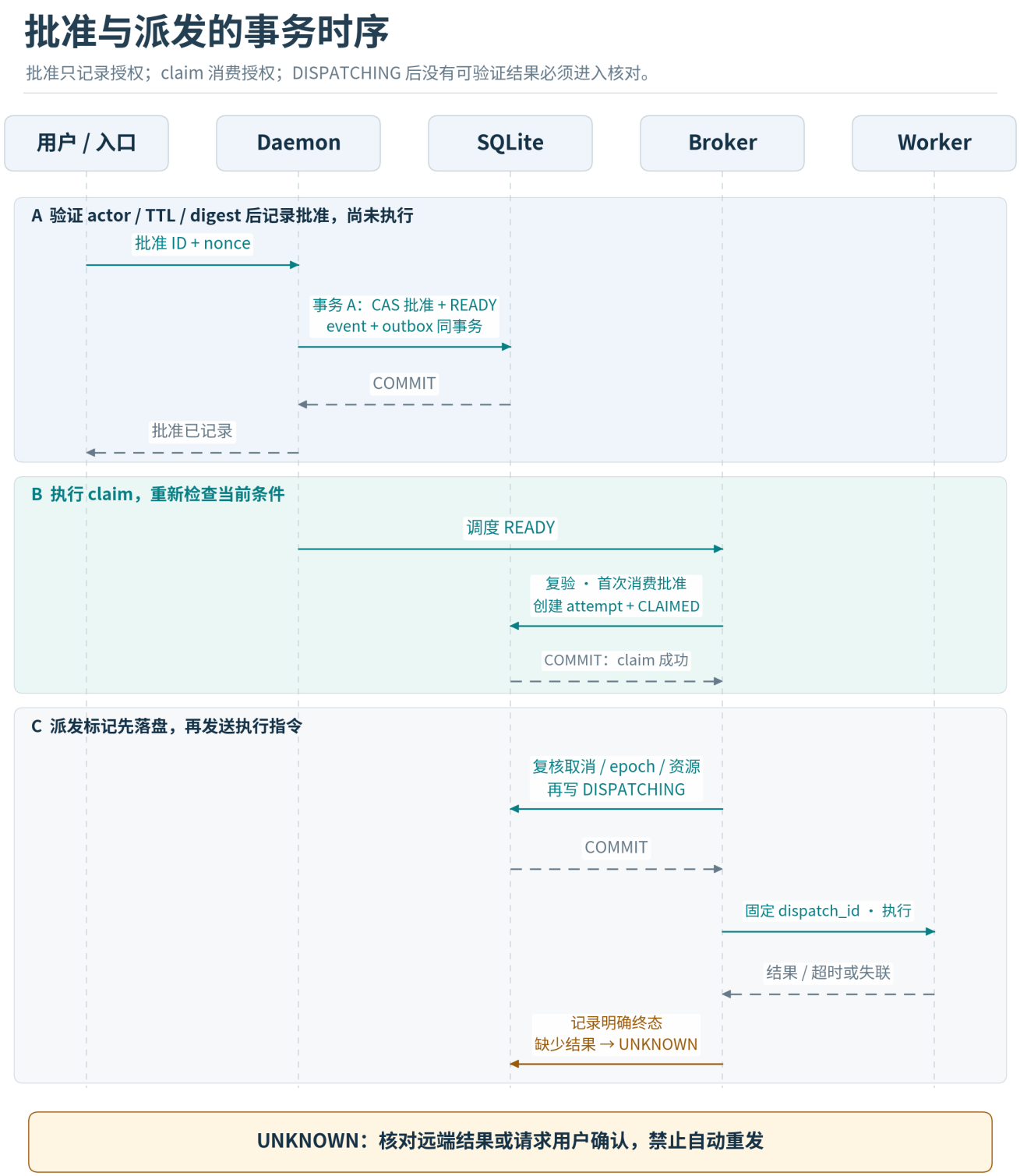
图 3 操作执行与恢复



图中未展开过期、撤销与取消；改变参数必须创建新 Operation。

设计来源：本报告模块与状态契约。图为工程设计，不是运行系统截图。

图 4 批准与派发时序



Broker 是 Daemon 内模块；所有事务经同一 writer；CONSUMED 不回退。

dispatch_id 属于 Attempt；Provider 幂等键属于 Operation；安全重试复验原 grant。

设计来源：本报告模块与状态契约。图为工程设计，不是运行系统截图。

图 5 持久化与事务



设计来源：本报告模块与状态契约。图为工程设计，不是运行系统截图。

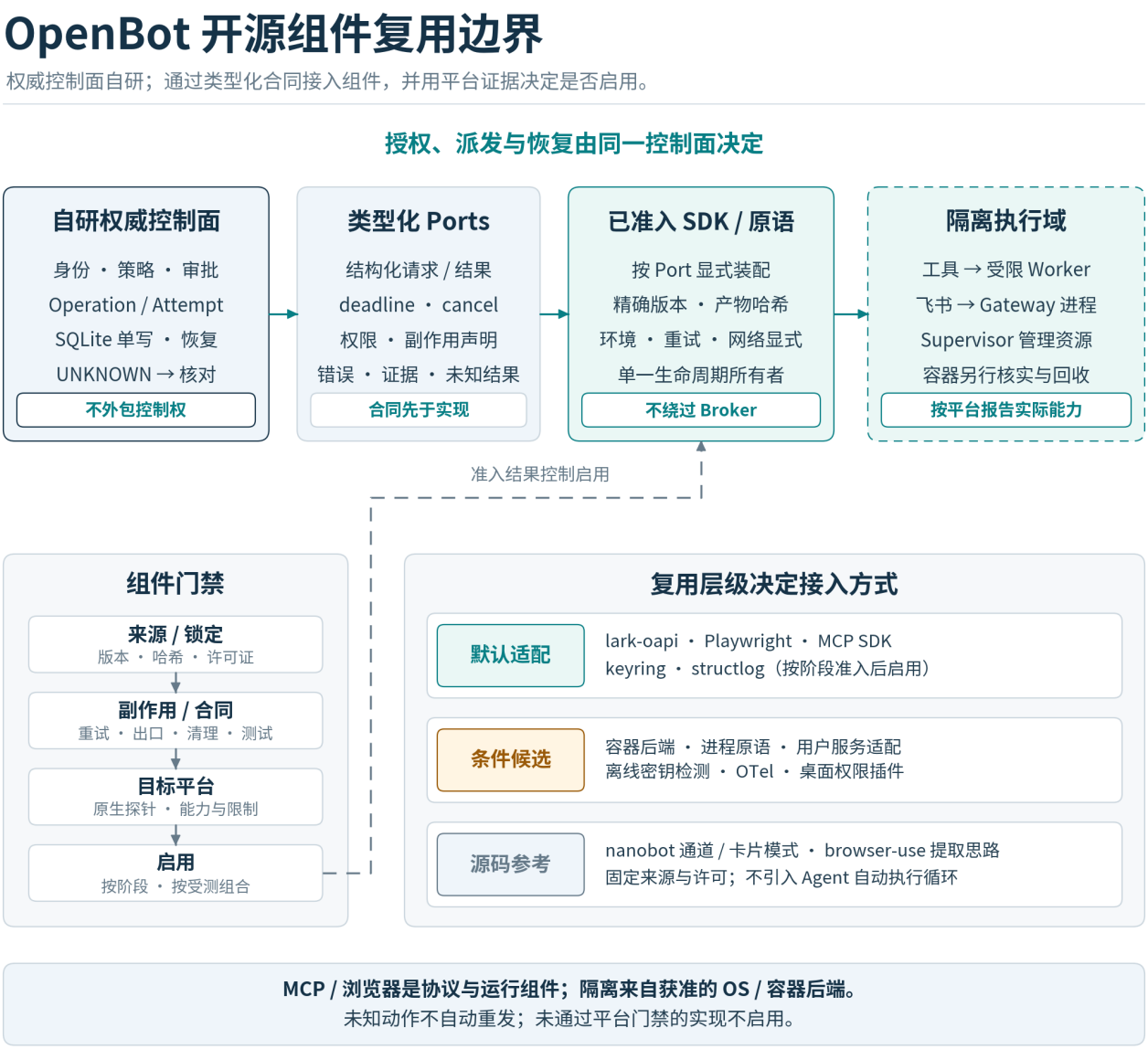
图 6 里程碑与门禁



原型、MVP、Beta 分别验收；不以代码量或生成完成代替发布门禁。

设计来源：本报告模块与状态契约。图为工程设计，不是运行系统截图。

图 7 自研控制面与开源复用边界



默认适配仍需准入；源码参考不进入运行依赖；进程分离本身不等于权限沙箱。

设计来源：本报告模块与状态契约。图为工程设计，不是运行系统截图。